



无线网络安全

第二章：无线局域网安全

第二章
无线局域网安全

无线局域网概述

无线局域网安全威胁

IEEE 802.1X协议分析

WAPI协议分析

IEEE 802.11i接入协议

无线局域网概述

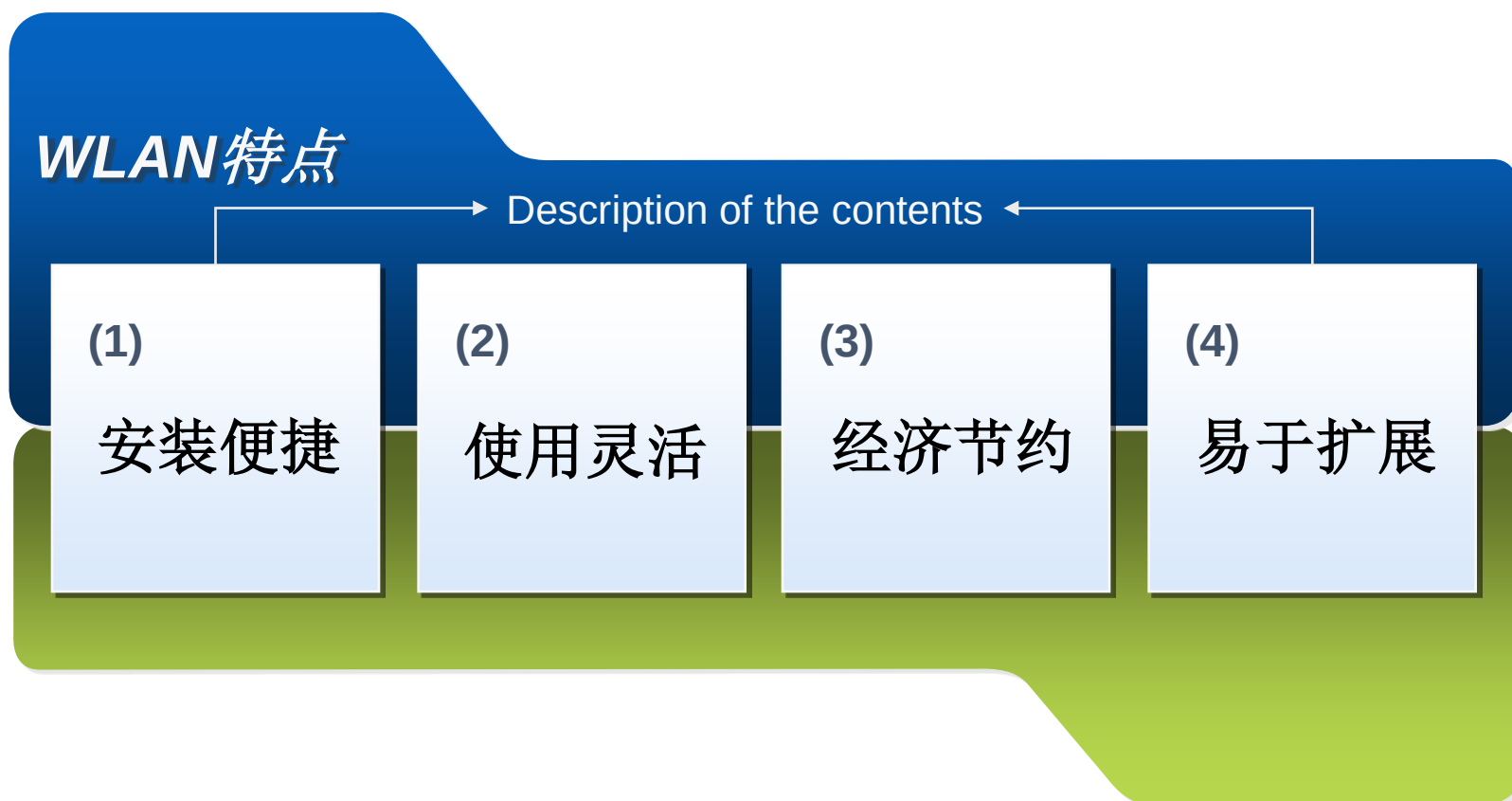
➤ 无线局域网(WLAN Wireless Local Area Networks)

- ✓ WLAN是计算机网络与无线通信技术相结合的产物，它是在不采用传统电缆线的同时，提供传统有线局域网的所有功能。



无线局域网概述

➤ 无线局域网的特点



无线局域网概述

➤ WLAN的组成

✓ 站 (Station, STA)

如使用**RG-WG54U**网卡的主机，使用**RG-WSG108**的笔记本电脑

✓ 无线介质 (Wireless Medium, WM)

空气

✓ 无线接入点 (Access Point, AP)

如**RG-WG54P**、**RG-P-780**、**RG-P-720**

✓ 分布式系统 (Distribution System, DS)

用来连接**AP**及其他网络设备的通信系统

无线局域网概述

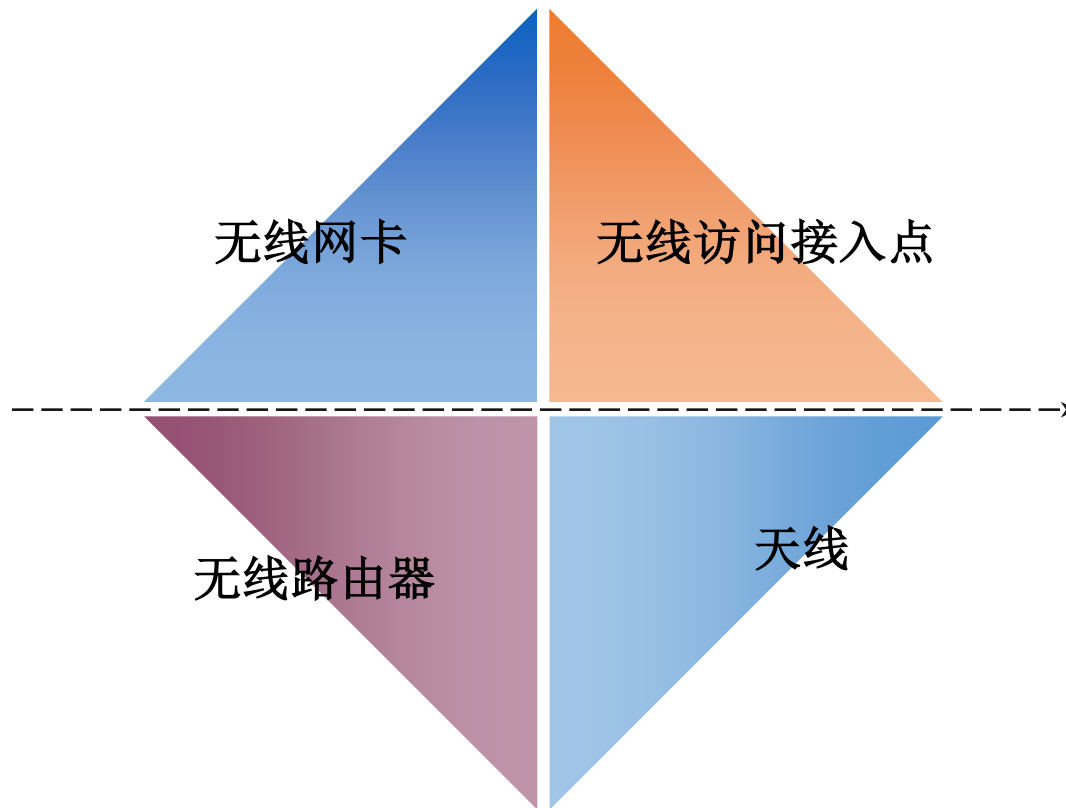
❖ WLAN的组成



- 一个完整的系统由站、无线介质、无线接入点、分布式系统组成

无线局域网概述

➤ WLAN的组成



无线局域网概述

➤ WLAN的组成



卡



室内无线AP



室外无线AP

无线局域网概述

➤ WLAN的组成



台式机



笔记本



手机

无线局域网概述

➤ WLAN的组成



PCI无线网卡



PCMCIA无线网卡



USB无线网卡

PCI无线网卡采用PCI接口，主要是针对台式机

PCMCIA无线局域网卡主要是针对笔记本

USB无线网卡可同时适应于台式机和笔记本电脑

无线局域网概述

➤ WLAN的组成

- ✓ 以一个基站为中心，所有的设备都连接到这个基站上，因此基站也称为接入点（Access Point）



无线局域网概述

➤ WLAN的组成

✓ 华硕WL-320gE无线



产品类别	无线接入器
网络标准	IEEE 802.11g、IEEE 802.11b
频率范围	2.4-2.5GHz
覆盖范围	11Mbps:室内40米、室外可达800米; 54Mbps:室内25米、室外可达300米 (会因为环境关系而影响距离)
传输速率	802.11g: 6、9、12、18、24、36、48、54 (Mbps) ; 802.11b: 1、2、5.5、11 (Mbps) ;
天线	5dBi

无线局域网概述

➤WLAN应用范围

✓主要适合于以下场所：

- 难以布线或者布线成本太高的地区；
- 校园会议室、展览厅、咖啡厅等人员变动频繁的地方；
- 餐厅、仓储超市等需要无线通信的场所；
- 家庭和SOHO用户；

无线局域网概述

WLAN技术标准

标准名称	颁布	说明
IEEE802.11	1997年	定义了2.4GHz微波波段和红外线物理层和MAC层规范
IEEE802.11a	1999年	定义了5GHz微波波段物理层和MAC层规范
IEEE802.11b	1997年	扩展的2.4GHz微波波段物理层和MAC层规范（DSSS）
IEEE802.11b+	2002年	扩展的2.4GHz微波波段物理层和MAC层规范（PBCC）
IEEE802.11c	2000年	关于802.11网络与普通以太网络的互通规范
IEEE802.11d	2000年	关于国际间漫游的规范
IEEE802.11e	2004年	基于无线局域网的质量控制规范
IEEE802.11f	2003年	漫游过程中的无线基站内部通信规范
IEEE802.11g	2003年	扩展的2.4GHz微波波段物理层和MAC层规范（OFDM）
IEEE802.11h	2003年	扩展的5GHz微波波段物理层与MAC层规范（欧洲）
IEEE802.11i	2004年	增强的无线局域网安全机制规范
IEEE802.11j	2004年	扩展的5GHz微波波段物理层与MAC层规范（日本）
IEEE802.11k	2005年	基于无线局域网的微波测量规范
IEEE802.11m	2006年	基于无线局域网的设备维护规范
IEEE802.11n	2007年	高吞吐量无线局域网物理层规范（100Mbps以上）

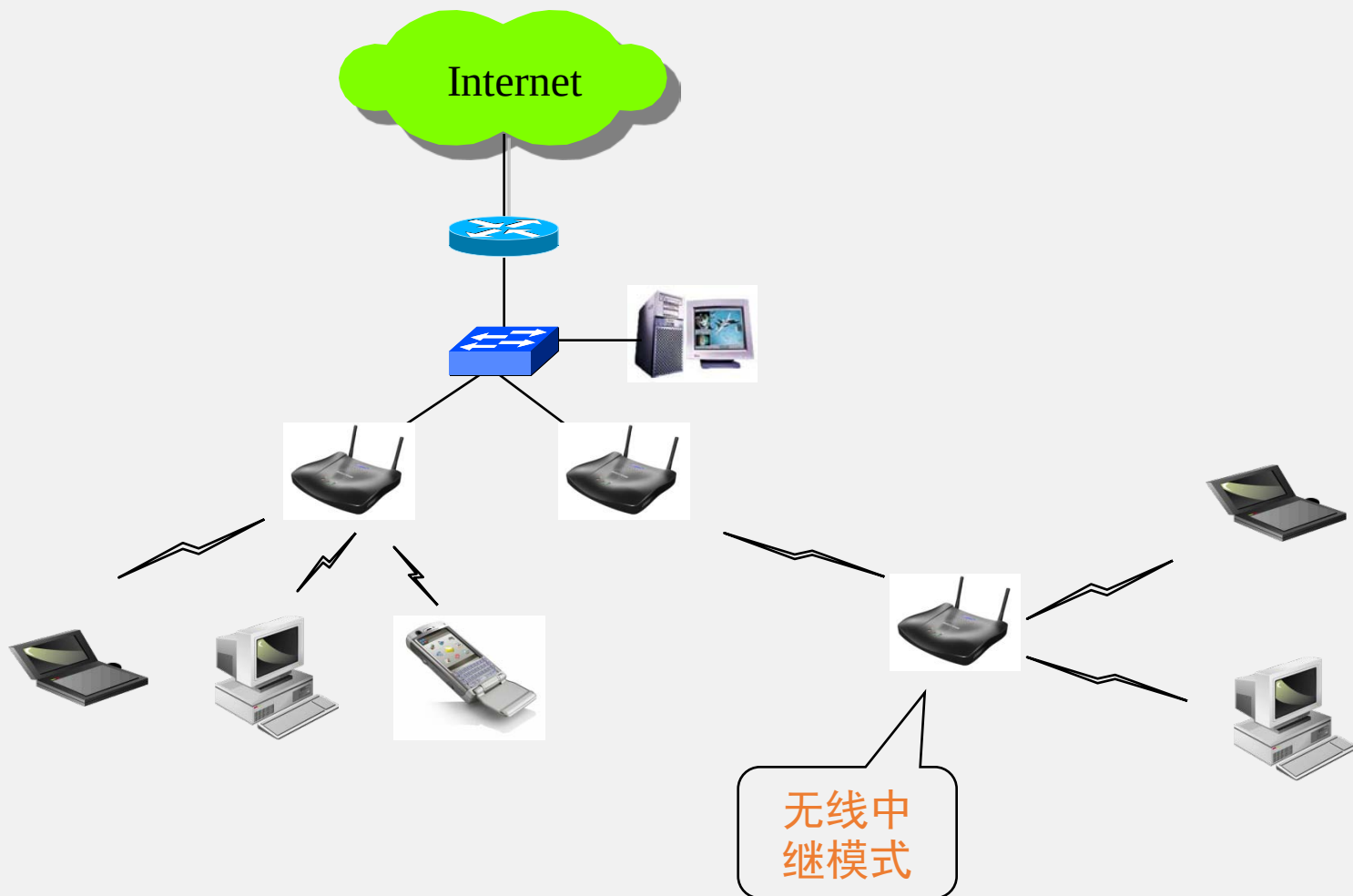
无线局域网概述

WLAN技术标准比较

标准	覆盖范围（米）	频率	最高速度	优点	缺点
802.11a	10到30	5GHz	54Mbps	速度快，不容易和其他设备产生干扰	与802.11b和802.11g不兼容，覆盖范围小
802.11b	室内30~50 室外100	2.4GHz	11Mbps	成本低，与802.11g兼容	速度慢
802.11g	室内30~50 室外100	2.4GHz	54Mbps	速度快，产品可选择性高，与802.11b兼容	比802.11b设备稍贵

无线局域网概述

AP的组网方式



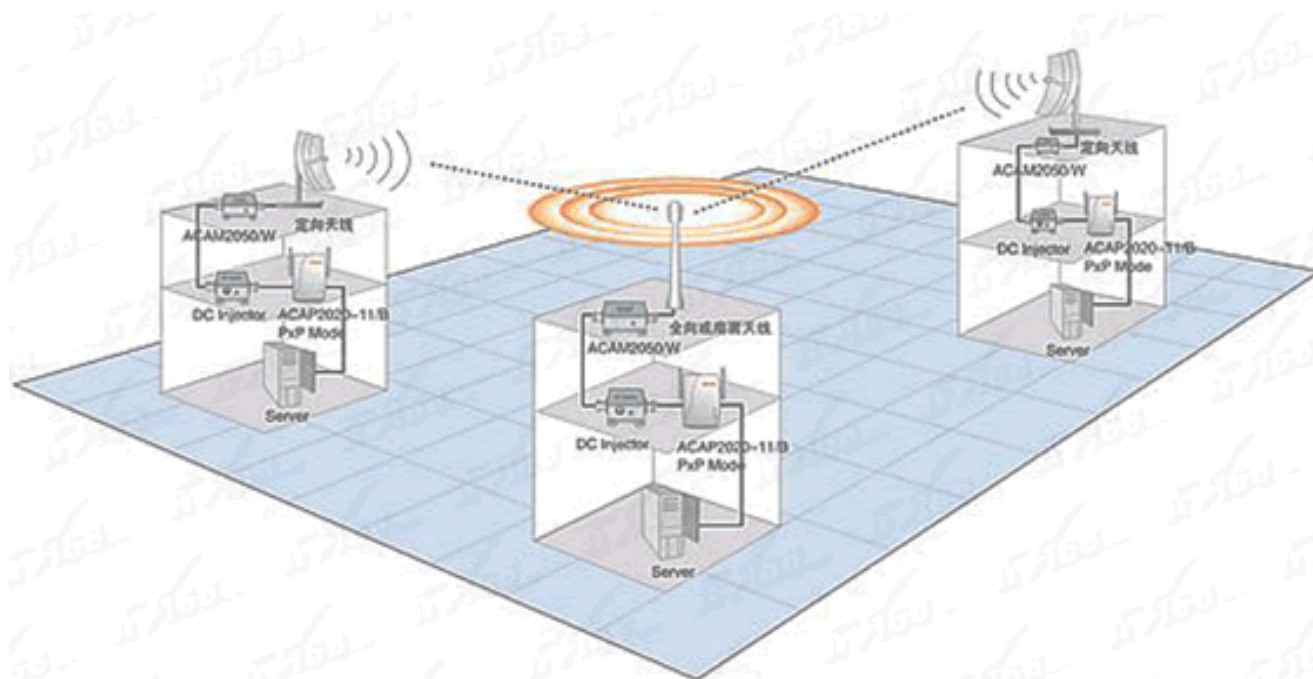
无线局域网概述

家庭和小型办公室WLAN接入



无线局域网概述

大型WLAN接入



点对多点无线网桥通常以一个网络为中心点发送无线信号，其他接收点进行信号接收



室外无线定向天线

无线局域网概述

无线局域网发展史

- ① 1971年夏威夷大学开发的基于封包技术的Aloha
- ② 1979年，瑞士IBM实验室的Gfeller（克费勒尔，德）首先提出了无线局域网的概念，采用红外线作为传输媒介；由于传输速率小于1Mb/s而没有投入使用
- ③ 1980年，加利福尼亚HP实验室的Ferrert（费拿）实现了**直接序列扩频调制**，速率达到100kb/s。因未能从FCC（Federal Communications Commission，中文为美国联邦通信委员会）获得需要的频段（900MHz）而最终流产
- ④ 此后几年，摩托罗拉等公司也进行了WLAN的实验，也都因为没有获得许可频段而未能如愿以偿

无线局域网概述

❖ 发展经历

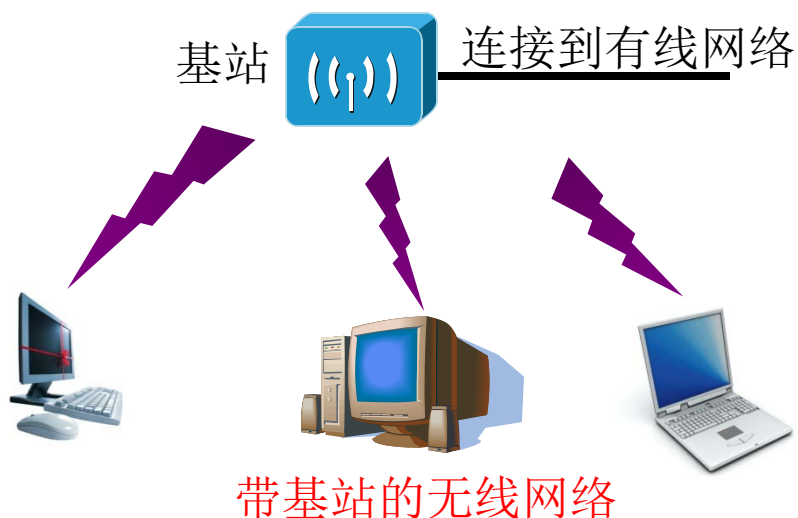
- ❖ 第一代无线局域网:1985年, FCC颁布的电波法规为无线局域网的发展扫清了道路
 - ❖ 分配2个频段: 专用频段和免许可证的频段
- ❖ 第二代无线局域网: 基于IEEE 802.11标准的无线局域网
- ❖ 第三、四代无线局域网
 - ❖ 符合IEEE 802.11b标准的归为第三代无线局域网;
 - ❖ 符合IEEE 802.11a、HiperLAN2和IEEE 802.11g标准称为第四代无线局域网

无线局域网概述

➤ 无线局域网定义

✓ 无线局域网是指在一个局部区域内计算机通过无线链路进行通信的网络,按照拓扑结构可分为:

- 带基站的无线网络（基础结构无线网络）
- Ad Hoc 网络（自组织网络）



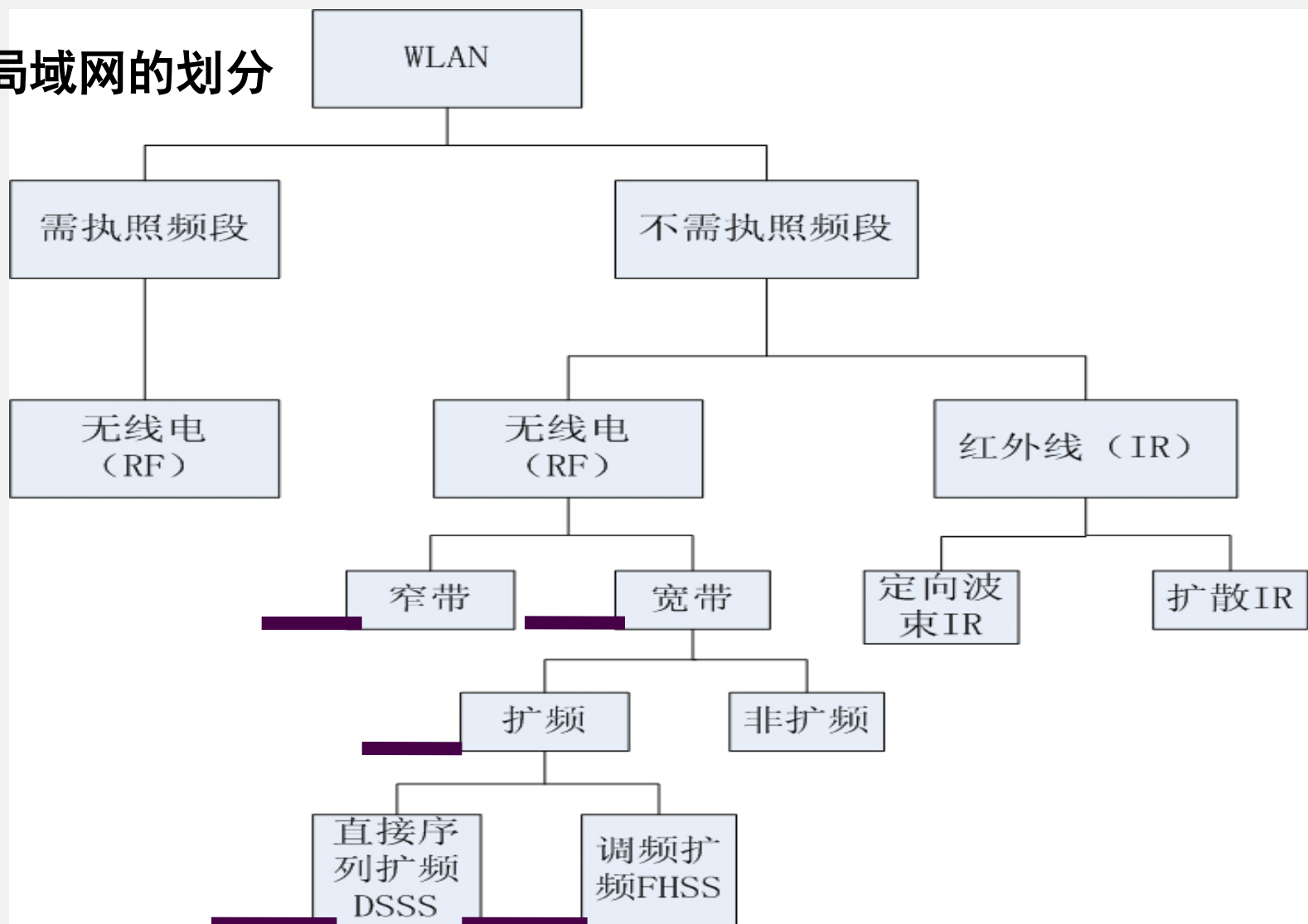
无线局域网概述

➤ 无线局域网基础结构

- ✓ 是指一个无线站点（如接入点AP，Access Point）充当中心站，所有无线结点对网络的访问均由其控制。接入点为通信的中心，为无线结点提供连接，是非对等的；为了与接入点关联，必须将无线结点的服务集标识符（SSID）配置成接入点的SSID

无线局域网概述

➤ 无线局域网的划分



无线局域网概述

➤ 扩频通讯

✓ 扩频的优势：

- 扩频通信是一种运用宽频调制的调制技术，其输出信号比原始信号的基带信息的带宽要宽很多
- 为WLAN、数字移动电话以及其他计算机和无线调制解调器设备提供了相对安全的数字通信
- 有较强的抗干扰能力和低截获率，因此也被广泛应用于军事上
- 见《扩频通讯》

无线局域网概述

➤ 无线局域网的局限性：

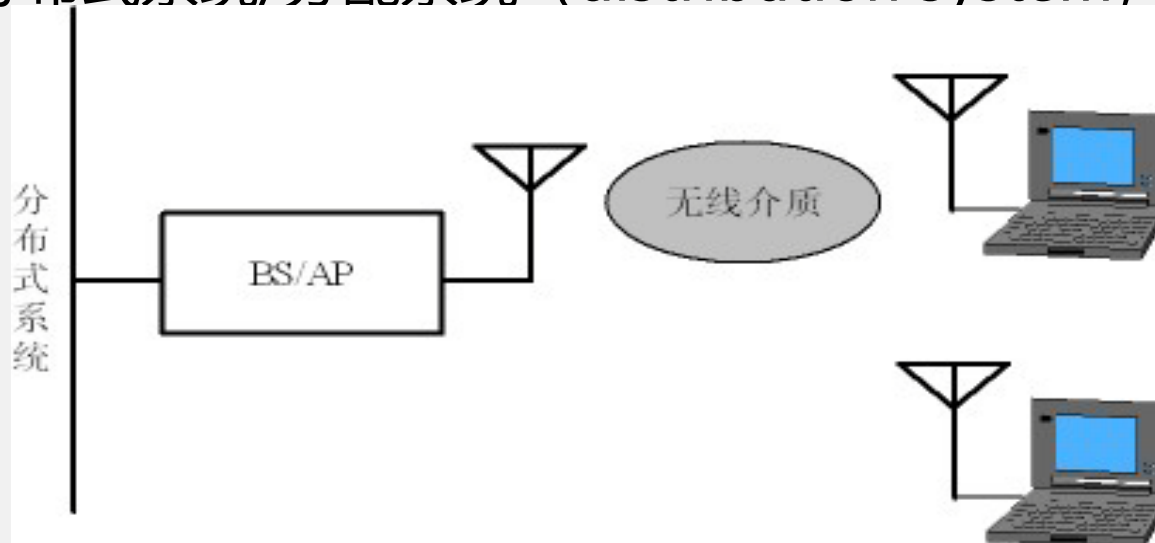
- ✓ 可靠性
- ✓ 带宽与系统容量
- ✓ 兼容性 (IEEE 802.11a/b/g/n)
- ✓ 覆盖范围
- ✓ 干扰 (类似英语四六级考试中的信号屏蔽)
- ✓ 安全性
- ✓

无线局域网概述

➤ 无线局域网的体系结构

✓ WLAN的物理组成:

- 无线工作站 (station, STA)
- 无线介质 (wireless medium, WM)
- 基站 (base station, BS) 或接入点 (access point, AP)
- 分布式系统/分配系统 (distribution system, DS)



无线局域网概述

➤ 无线局域网的体系结构

✓ 无线工作站

- 站(点)也称主机(Host)或终端(Terminal)，是无线局域网的最基本组成单元，包括以下几部分：
 - 终端用户设备
 - 台式计算机、便携式计算机、掌上计算机、PDA等
 - 无线网络接口
 - 无线网卡或者Modem
 - 网络软件
 - 网络通信协议等

无线局域网概述

➤ 无线局域网的体系结构

✓ 无线工作站

● WLAN中的站可分为3类：

- 固定站：位置固定不变
- 半移动站：经常改变物理位置，但它在移动状态下并不要求保持与网络的通信
- 移动站：在移动状态下也可保持与网络的通信，典型的移动速率为2~10m/s

无线局域网概述

➤ 无线局域网的体系结构

✓ 分布式系统

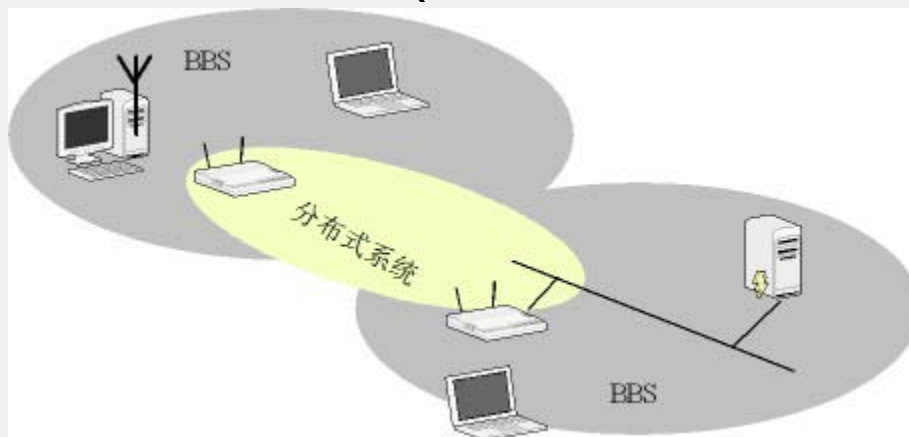
- WLAN中，站之间的通信距离由于天线的辐射能力有限和应用环境的不同而受到限制，无线局域网所能覆盖的区域范围称为服务区域（Service Area, SA）
- WLAN中，移动站的无线收发机及地理环境确定的通信覆盖区域（服务区域）称为基本服务区（Basic Service Area, BSA），也称小区（Cell）；BSA通常不能太大，一般100m以内
- 一个BSA内彼此通信的一组主机组成一个基本服务集（Basic Service Set, BSS）

无线局域网概述

➤ 无线局域网的体系结构

✓ 分布式系统

- 为了覆盖更大的区域，把多个BSA通过分布式系统连接起来，形成一个扩展服务区（Extended Service Area, ESA）
- 通过DS互相连接起来的属于同一个ESA的所有主机组成一个扩展服务集（Extended Service Set, ESS）

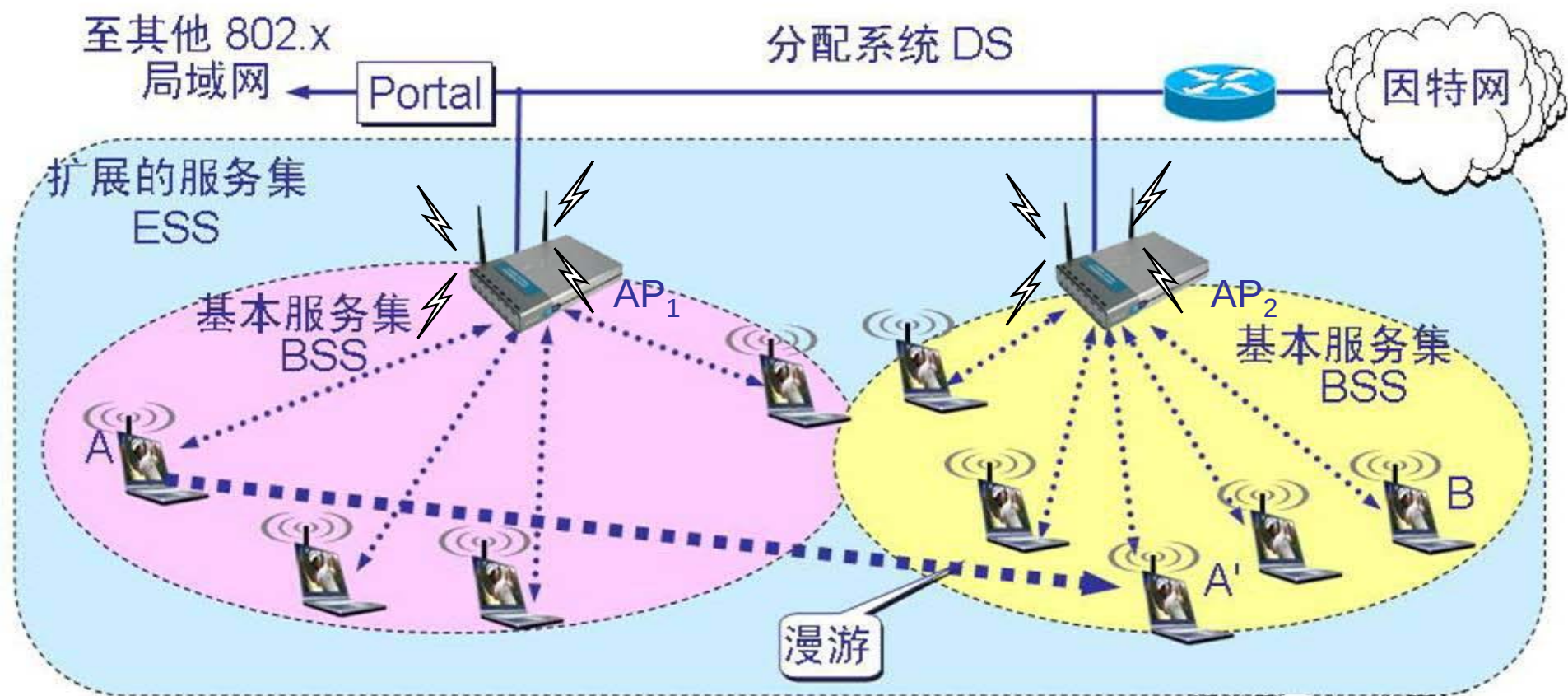


无线局域网概述

➤ 无线局域网的体系结构

✓ 分布式系统

● IEEE 802.11的基本服务集和扩展服务集

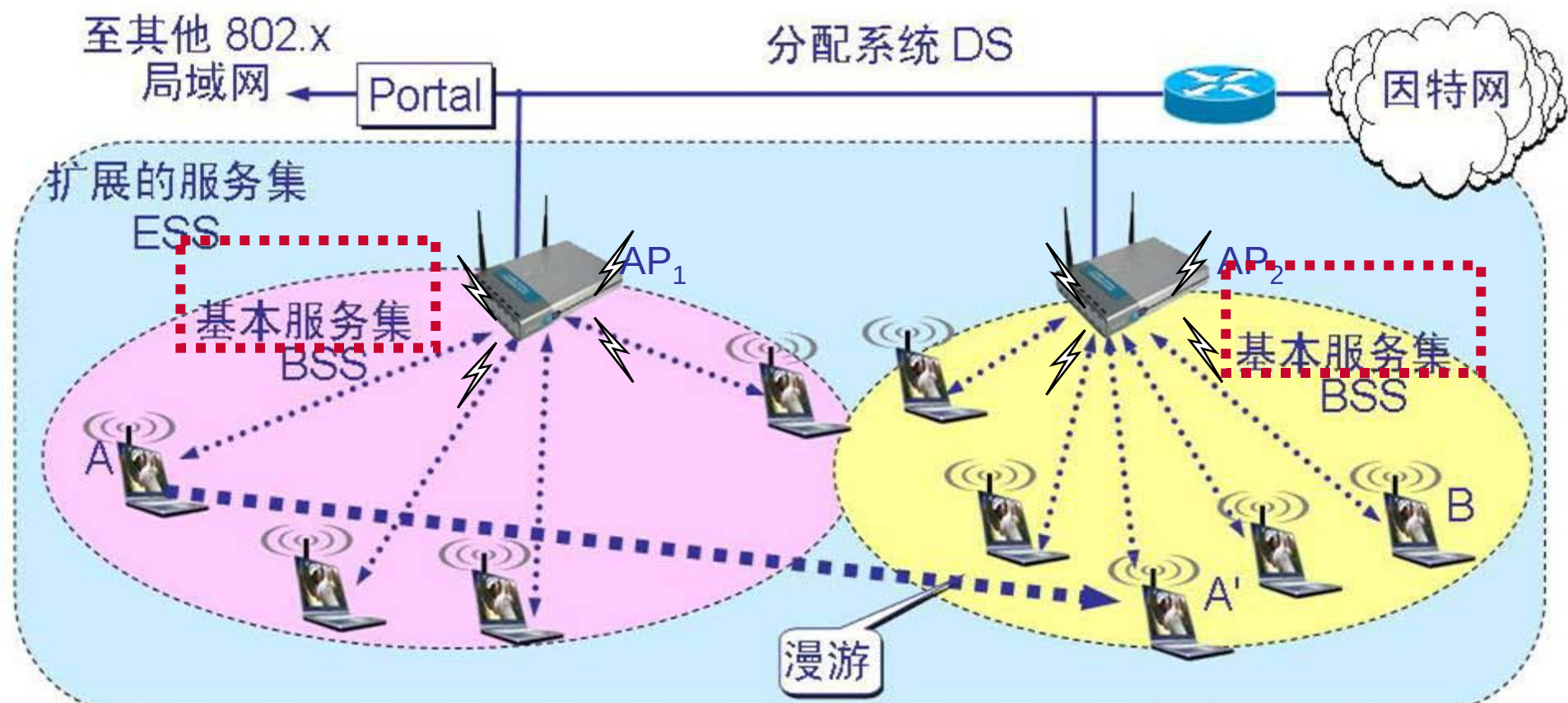


无线局域网概述

➤ 无线局域网的体系结构

✓ 分布式系统

- 所有的站在本 BSS 内可以直接通信，但在和本 BSS 以外的站通信时，都要通过本 BSS 的基站

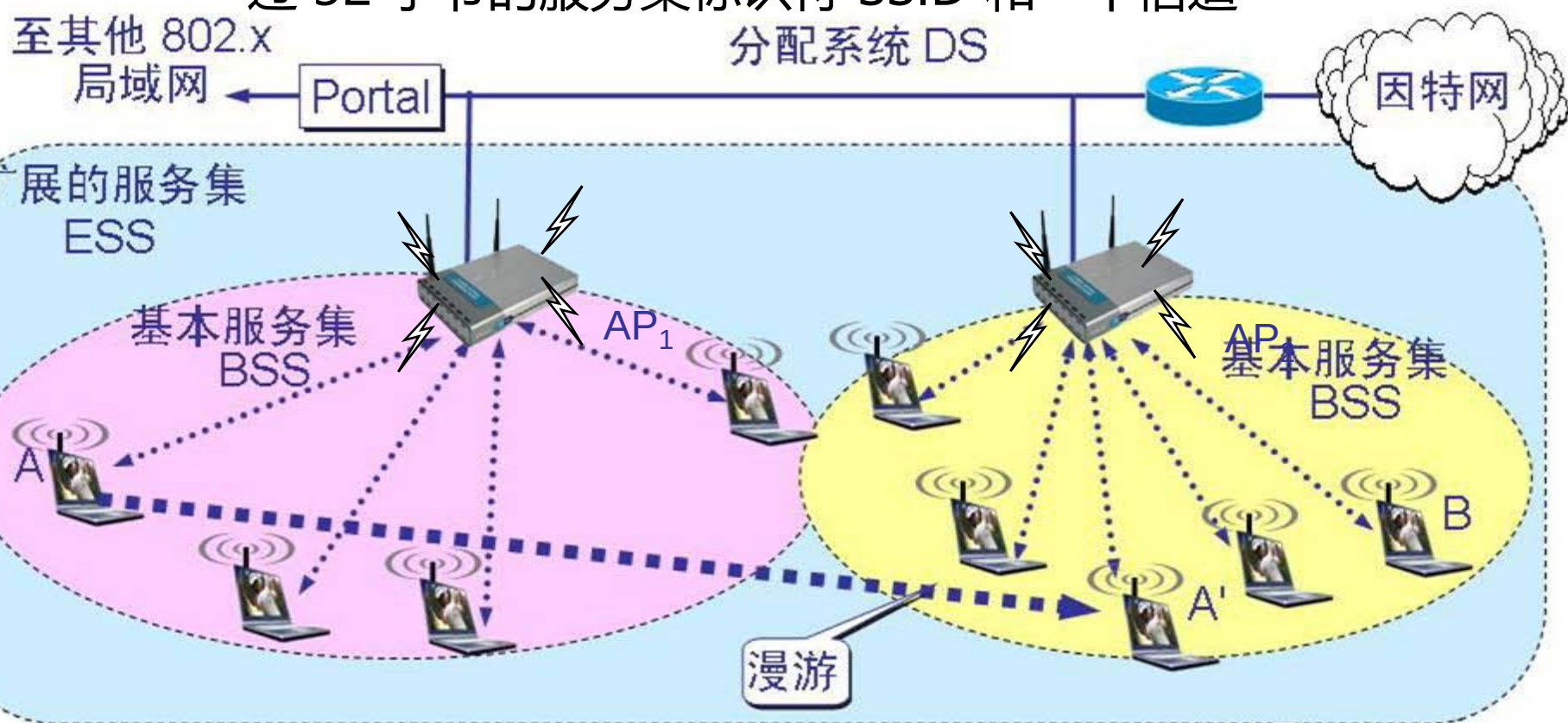


无线局域网概述

➤ 无线局域网的体系结构

✓ 分布式系统

- 当网络管理员安装 AP 时，必须为该 AP 分配一个不超过 32 字节的服务集标识符 SSID 和一个信道

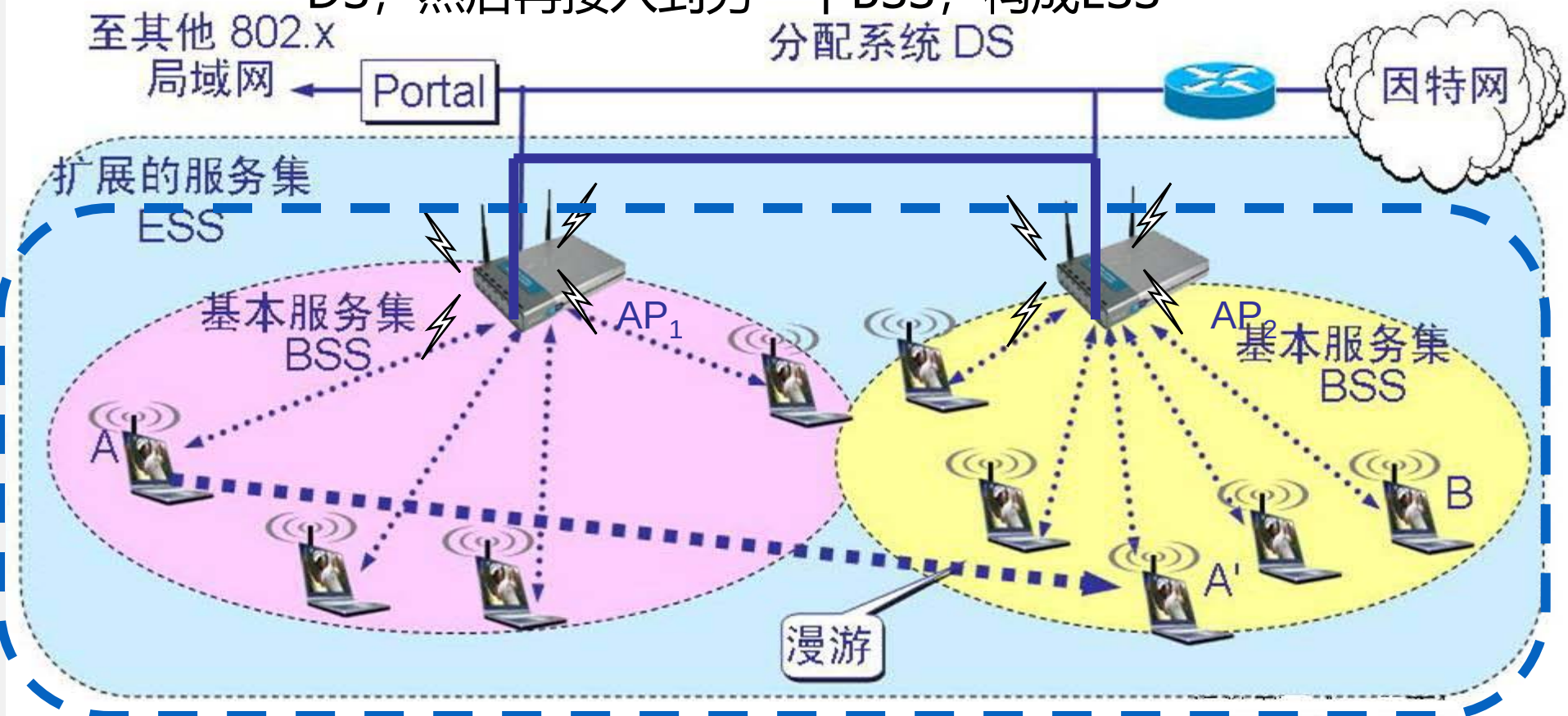


无线局域网概述

➤ 无线局域网的体系结构

✓ 分布式系统

- 一个BSS可以是孤立的，也可通过接入点 AP 连接到一个 DS，然后再接入到另一个BSS，构成ESS

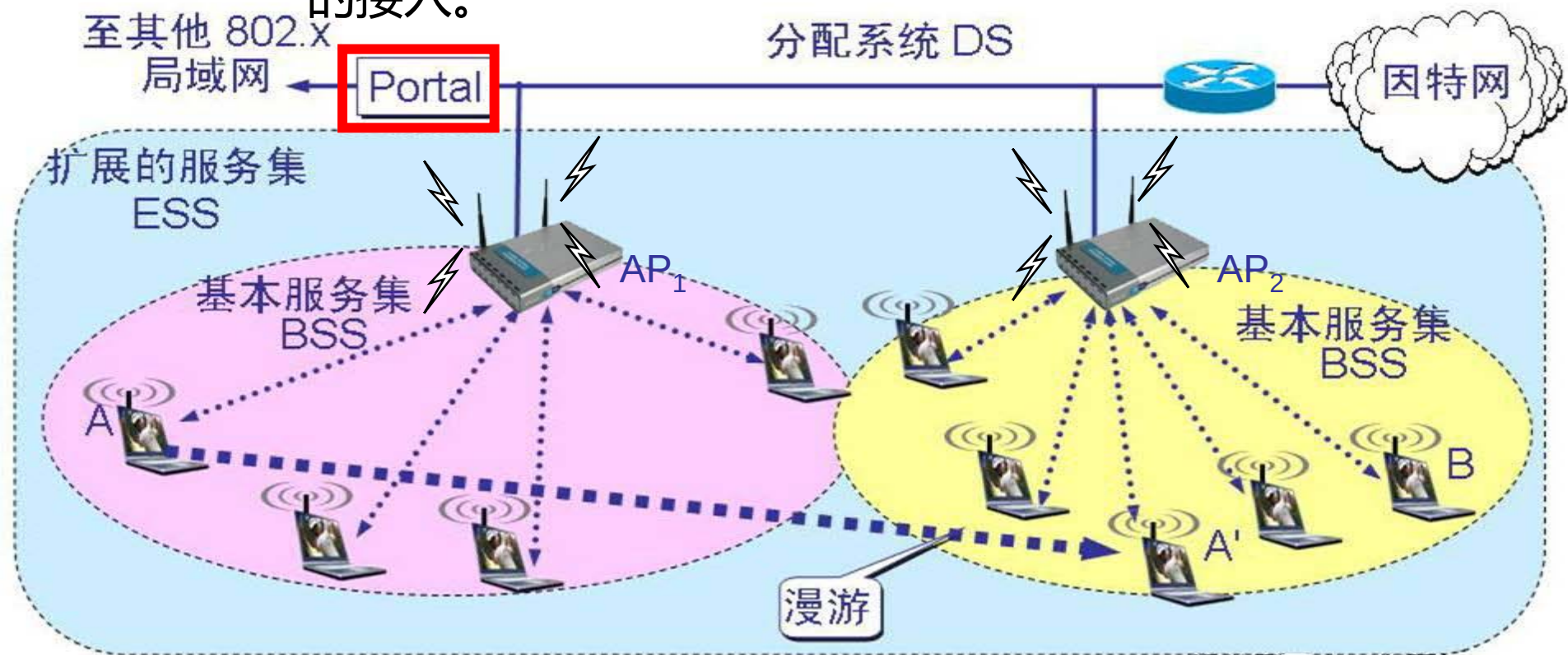


无线局域网概述

➤ 无线局域网的体系结构

✓ 分布式系统

- ESS 还可通过叫做门户/入口(portal)为无线用户提供到非 802.11 无线局域网（例如，到有线连接的因特网）的接入。



无线局域网概述

➤ 无线局域网的体系结构

✓ 分布式系统

● 越区切换与漫游

- 当一个站从一个BSA移动到另一个BSA时，这种移动称为散步（walking）或越区切换（handoff 或 handover）是链路层的移动
- 当一个站从一个ESA移动到另一个ESA时，也就是从一个子网移动到另一个子网，称为漫游（roaming）是网络层或者IP层的移动

无线局域网安全概述

- 由于无线局域网通过无线电波传递信息，所以在数据发射机覆盖区域内的几乎任何一个WLAN用户都能接触到这些数据。WLAN所面临的基本威胁主要有信息泄露、完整性破坏、拒绝服务和非法使用。
- 主要的可实现的具体威胁包括无授权访问、窃听、伪装、篡改信息、否认、重放、重路由、错误路由、删除信息、网络泛洪等。

无线局域网安全概述

➤ 无授权访问

- ✓ 是指入侵者能够访问未授权的资源或收集有关信息。对资源的非授权访问可以分为两种：
 - 一种是入侵者突破安全防线来访问资源；
 - 一种是入侵者盗用合法用户授权，而以合法人的身份进行非法访问。

无线局域网安全概述

➤ 窃听

- ✓ 是指入侵者能够通过通信信道来获取消息。
- ✓ 无线网络的电磁波辐射难以精确地控制非某个范围内，所以有数据发射机覆盖的区域内的几乎任何一个无线网络用户都能获取这些数据。

无线局域网安全概述

➤伪装

- ✓是指入侵者能够伪装成其他实体或授权用户，对机密信息进行访问；
- ✓或者伪装成基站，以接受合法用户的信息。

无线局域网安全概述

➤ 篡改信息

- ✓ 当非授权用户访问系统资源时，会篡改信息，从而破坏信息的完整性。

无线局域网安全概述

➤ 否认

- ✓ 是指接受信息或服务的一方，否认曾经发送过请求或接收过信息或服务。这种安全威胁主要来自系统内其他合法用户，而不是来自于未知的攻击者。

无线局域网安全概述

➤重放、重路由、错误路由、删除信息

- ✓重放攻击是攻击者复制有效的信息事后重新发送或重用这些信息以访问某种资源。
- ✓重路由攻击是指攻击者改变消息路由以便捕获有关信息。
- ✓错误路由攻击能够将消息，路由到错误的目的地。
- ✓删除消息是攻击者在消息到达目的地前将消息删除掉，使得接受着无法收到消息。

无线局域网安全概述

➤ 网络泛洪

- ✓ 当入侵者发送大量假的或无关的消息时，会发送网络泛洪，从而使得系统忙于处理这些伪造的消息而耗尽其资源，进而无法对合法用户提供服务。

无线局域网络安全协议

- ❖ WEP
- ❖ WAP
- ❖ IEEE 802.11i
- ❖ WAPI

无线局域网络安全协议

❖ WEP

- 是针对无线网络而开发的，1999年9月获准成为无线网络安全标准。WEP理论上应当提供与有线网络同等的安全等级，但是其中却存在很多问题。
- 尽管已经尽力提升WEP系统，它仍然是高度脆弱的解决方案。WEP于2004年正式被放弃。

无线局域网络安全协议

❖ WPA

- 在802.11i无线安全标准的开发过程中，WPA被用作WEP的临时安全增强措施。在WEP被正式放弃的前一年，WPA正式被采用。大多数现代WPA应用程序使用预共享密钥（PSK）和临时密钥完整性协议（TKIP（/ti:kip/））进行加密。WPA Enterprise使用身份验证服务器生成密钥和证书。
- WPA，就像WEP一样，经过概念验证和应用公共演示后，很容易受到入侵。然而，对此协议构成最大威胁的攻击不是直接攻击，而是在无线网络保护设置WPS（为简化设备与现代接入点的链接而开发的辅助系统）上进行的攻击。

无线局域网络安全协议

❖ IEEE 802.11i

- 是802.11为新一代WLAN制定的安全标准，主要包括加密技术：TKIP（Temporal Key Integrity Protocol）、AES（Advanced Encryption Standard）。
- 认证方面，IEEE 802.11i采用802.1x接入控制，实现无线局域网的认证与密钥管理，并通过EAP-Key的四向握手过程与组密钥握手过程，创建、更新加密密钥，实现802.11i中定义的鲁棒安全网络（Robust Security Network, RSN）的要求。

无线局域网络安全协议

❖ WAPI

- Wireless LAN Authentication and Privacy Infrastructure
无线局域网鉴别和保密基础结构。
- WAPI是我国首个在计算机宽带无线网络通信领域自主创新并拥有知识产权的安全接入技术标准，也是我国无线局域网安全强制性标准

无线局域网络安全协议

➤无线网络安全标准比较

安全功能		WEP	WPA	IEEE 802.11i	WAPI
认证和加密	认证	单向认证	双向认证 IEEE 802.1x架构 EAP协议	双向认证 IEEE 802.1x架构 EAP协议	双向认证 WAI协议 (公钥证书)
	加密	加密密钥短， 易被破解	TKIP算法， 安全性较高	TKIP/CCMP算法， 安全性较高	WPI协议 (SMS4算法)
	绑定关系	认证和加密使用同一密钥， 绑定使用	认证与加密协议分离； 认证与加密算法可未 绑定使用	认证与加密协议分离； 认证与加密算法可未 绑定使用	认证与加密协议 分离；认证与加 密算法绑定使用
	终端实现	绑定	现有终端均绑定使用， 未提供“认证+不加 密”模式；可升级支 持	现有终端均绑定使用， 未提供“认证+不加 密”模式；可升级支 持	现有终端支持算 法实现未开启使用
完整性		支持	支持	支持	支持
安全性		安全性较低	安全性较高	安全性较高	安全性较高

无线局域网络安全协议

➤ 802.11的加密机制—WEP协议

- ✓ IEEE802.11 1999年版本的协议中，规定了安全机制WEP (Wried Equivalent Privacy)，中文名叫有限等价加密。
- ✓ WEP提供3个方面的安全保护：数据机密性、访问控制和数据完整性。
- ✓ 核心是RC4序列密码算法，用秘钥作为种子通过伪随机数产生器 (PRNG) 产生伪随机秘钥序列 (PRKS) 和明文相异或后得到密文序列。

无线局域网络安全协议

➤ WEP的设计思想是

- ✓ 通过使用RC4序列密码算法加密来保护数据的机密性；通过移动站Station与访问点AP共享同一秘钥实施接入控制；通过CRC循环冗余校验值来保护数据的完整性。

一串随机的文本[RandomText] xor 等长的明文[PlainText] ==> 密文[CipherText]

同一串随机的文本[RandomText] xor 密文[CipherText] ==> 明文[PlainText]

$01100011 \wedge 01010101 = 00110110$

$01100011 \wedge 00110110 = 01010101$

无线局域网络安全协议

➤ WEP安全性— CRC32原理

- ✓ 在一个 p 位二进制数据序列之后，附加一个 r 位二进制检验码(序列)，从而构成一个总长为 $n = p + r$ 位的二进制序列
- ✓ 附加在数据序列之后的这个检验码与数据序列的内容之间存在着某种特定的关系。
- ✓ 如果因干扰等原因使数据序列中的某一位或某些位发生错误，这种特定关系就会被破坏。
- ✓ 因此，通过检查这一关系，就可以实现对数据正确性的检验。

无线局域网络安全协议

➤ WEP的安全性—RC4

- ✓ RC4于1987年提出，和DES算法一样，是一种对称加密算法，也就是说使用的密钥为单钥（或称为私钥）。
- ✓ 不同于DES的是，RC4不是对明文进行分组处理，而是字节流的方式依次加密明文中的每一个字节，解密的时候也是依次对密文中的每一个字节进行解密。

无线局域网络安全协议

➤ WEP的安全性—RC4

- ✓RC4算法的特点是算法简单，运行速度快，而且密钥长度是可变的，可变范围为1-256字节(8-2048比特)
- ✓在如今技术支持的前提下，当密钥长度为128比特时，用暴力法搜索密钥已经不太可行，所以可以预见RC4的密钥范围仍然可以在今后相当长的时间里抵御暴力搜索密钥的攻击。
- ✓实际上，如今也没有找到对于128bit密钥长度的RC4加密算法的有效攻击方法。

无线局域网络安全协议

➤ WEP加密过程

①使用**CRC32**计算明文的完整性校验值**ICV**

数据

ICV

生成一个**IV**（初始向量），并进行密钥的预先选择，生成密钥种子

IV

+

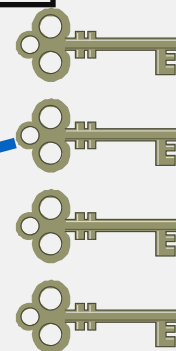
RC4

输入密钥**seed**，并使用**RC4**生成密钥流

密钥流

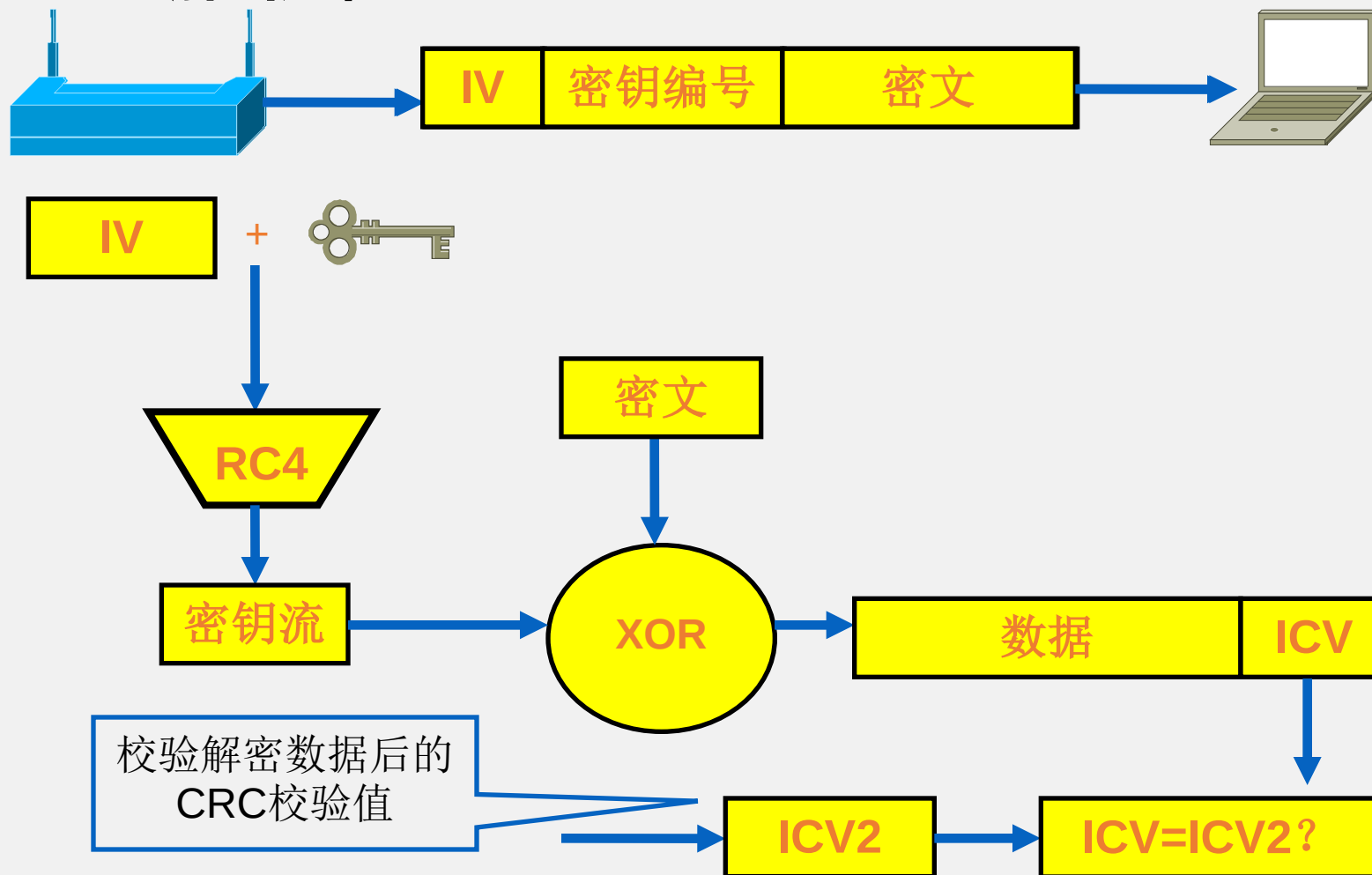
XOR

密文



无线局域网络安全协议

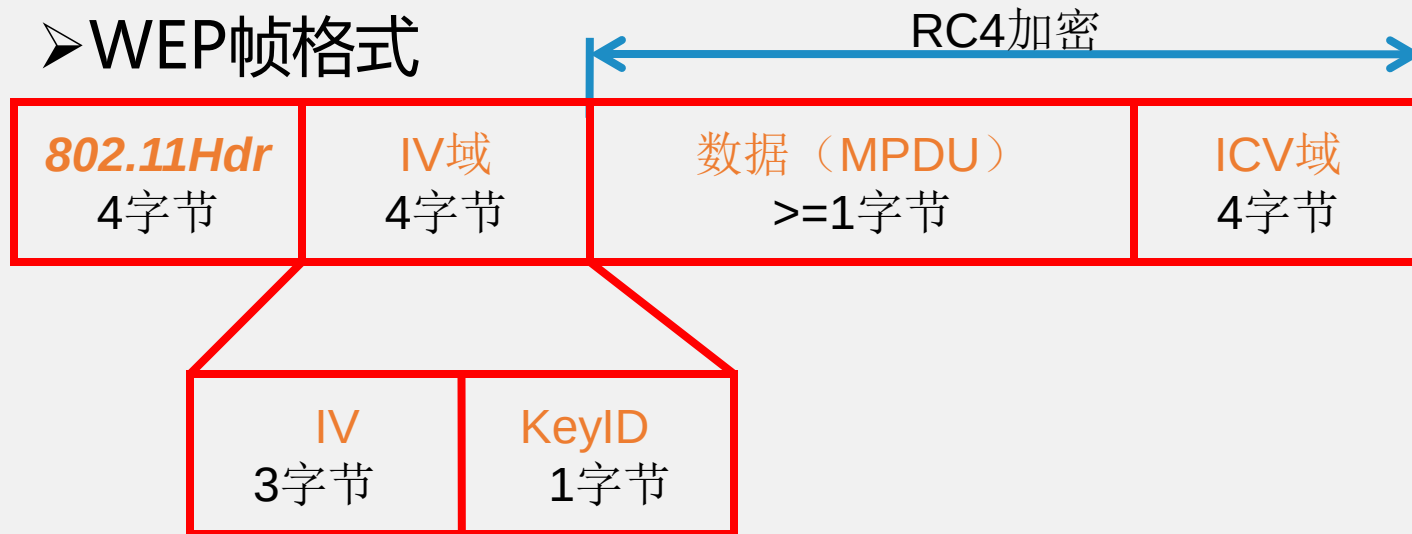
➤ WEP解密过程



无线局域网网络安全协议

➤ WEP加密过程

➤ WEP帧格式



- WEP使用预先建立的共享密钥（支持4个），具体使用哪个密钥由WEP帧中的KeyID决定
- IV和WEP密钥共同生成RC4算法的种子

无线局域网络安全协议

➤ WEP安全性—认证

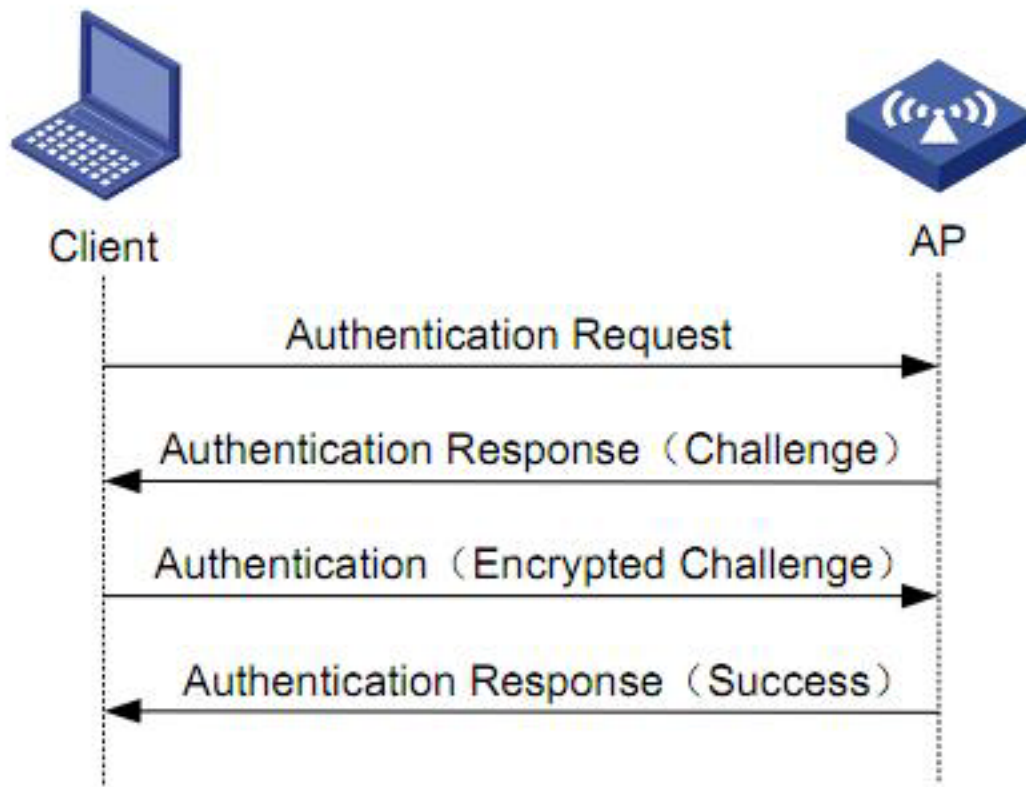


图2 共享密钥认证过程

无线局域网络安全协议

➤ WEP安全性—认证

➤ 共享密钥认证

➤ 需要客户端和设备端配置相同的共享密钥。

➤ 认证过程

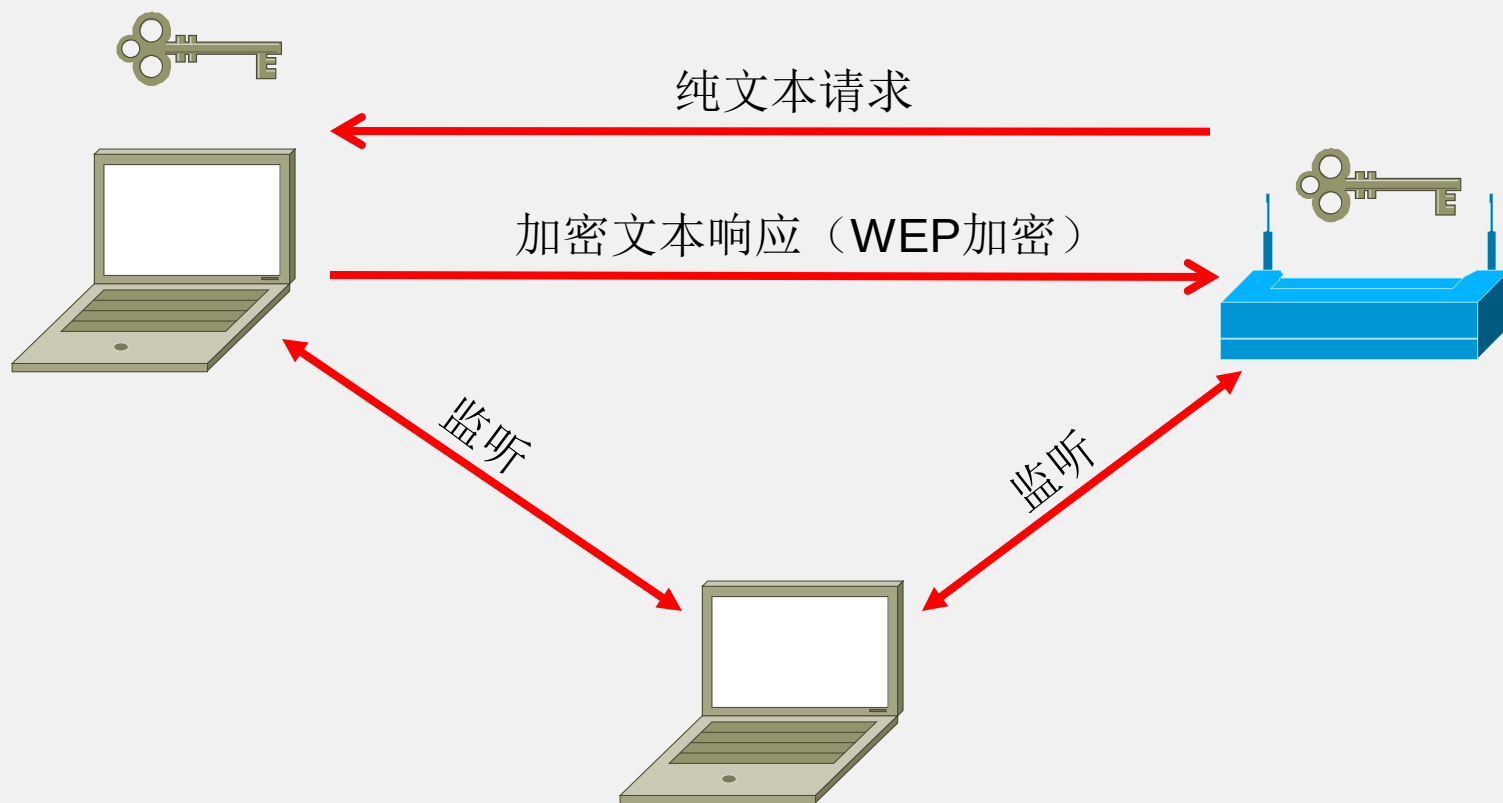
- 客户端先向设备发送认证请求，无线设备端会随机产生一个 Challenge 包（即一个字符串）发送给客户端；
- 客户端会将接收到字符串拷贝到新的消息中，用密钥加密后再发送给无线设备端；
- 无线设备端接收到该消息后，用密钥将该消息解密，然后对解密后的字符串和最初给客户端的字符串进行比较。
- 如果相同，则说明客户端拥有无线设备端相同的共享密钥，即通过了 Shared Key 认证；否则 Shared Key 认证失败。

无线局域网络安全协议

➤ WEP安全性—认证

➤ 共享密钥认证

➤ 认证过程



无线局域网络安全协议

➤ WEP安全性—认证

✓ WEP认证机制存在的问题

- 身份认证是单向的，即AP对申请者接入的移动客户端进行身份认证，而移动客户端并不能对AP的身份进行认证。因此，这种单向的认证方式导致可能存在假冒的AP。
- 从WEP协议身份认证过程可以发现，AP会以明文的形式把128字节的随机序列发送给移动客户端，所以网络内的其他设备就可以监听整个认证过程。捕获他们之间的数据包就能分析出加密密钥流。而得到密钥流，任何人都能向AP提出访问请求。因此WEP协议认证方式对于监听攻击失效。

无线局域网络安全协议

➤ WEP安全性—认证

✓ WEP认证机制存在的问题

- 在802.11安全机制的IEEE标准过程中，加密专家只对WEP算法进行了很少的组内评审，这导致了WEP遗留了多处漏洞
 - WEP加密是可选功能
 - 较小的IV空间（IV冲突）
 - 没有密钥交换/管理机制
 - 非常弱的数据完整性检查（CRC32）
 - 有缺陷的身份验证系统

无线局域网络安全协议

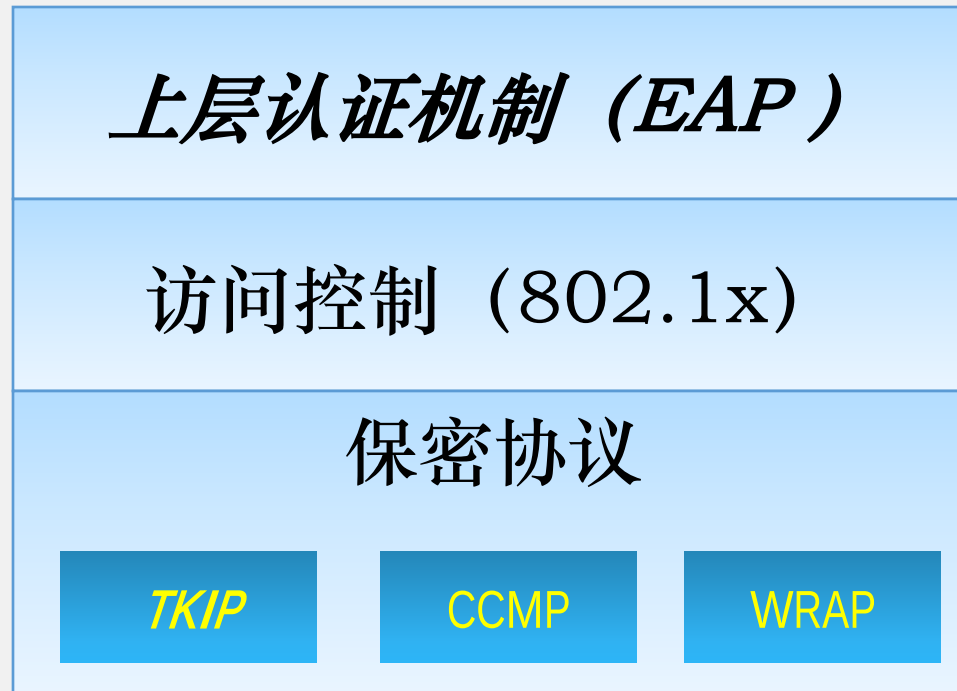
➤新的安全技术

- 由于WEP的安全漏洞，IEEE 802.11i工作组和生产厂商Wi-Fi联盟以及我国都提出了新的安全体系：
 - IEEE 802.11i
 - WPA（Wi-Fi联盟，WEP到IEEE 802.11i的过渡方案）
 - WAPI（无线网认证和保密基础结构，我国）

无线局域网络安全协议

➤ WPA

➤ 协议栈



- EAP: 扩展认证协议
- TKIP: Temporal Key Integrity Protocol, 暂时密钥完整性协议
- CCMP: 计数器模式密码块链消息完整码协议
- WRAP: Wireless Robust Authenticated Protocol, 无线增强认证协议

无线局域网络安全协议

➤ WPA

➤ IEEE 802.1x协议

- IEEE 802.1x于2001年6月由IEEE正式发布，是基于端口的访问控制方案，同时还有认证和计费功能
- 802.1x并非专门针对WLAN设计，它适用于符合802标准的各种网络
- 核心是扩展认证协议（Extensible Authentication Protocol, EAP）

无线局域网络安全协议

➤ IEEE 802.1x协议-协议栈

验证层

TLS

CHAP

Kerberos

扩展认证协议

EAP层

EAP over LAN (EAPoL)*

MAC层

PPP

802.3

802.5

802.11

TLS: 安全传输层协议

CHAP: PPP (点对点协议) 询问握手认证协议

Kerberos: 网络认证协议

点到点协议 (Point to Point Protocol, PPP)

无线局域网络安全协议

➤ IEEE 802.1x协议

➤ 802.1x由三个主要逻辑实体组成：

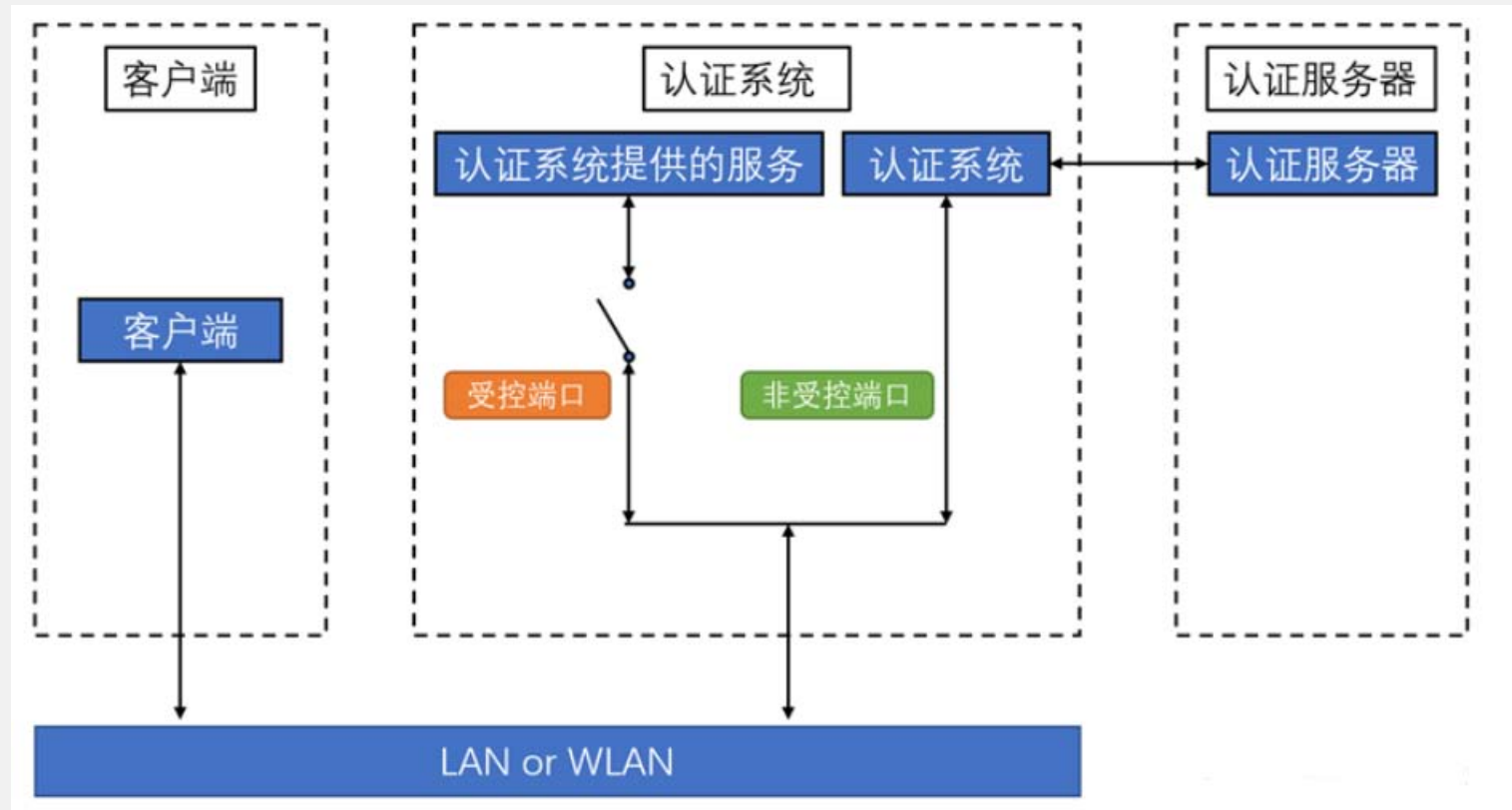
- 申请者 (Supplicant) -- 连接到网络的客户系统
- 认证者 (Authenticator) -- 以太网交换机或者申请者试图连接的其他设备，如AP
- 认证服务器 (Authentication Server) -- 储存申请者身份信息信息的服务器，通常是某种AAA服务器
 - AAA是验证、授权和记账Authentication、Authorization、Accounting



无线局域网络安全协议

➤ IEEE 802.1x协议

➤ 802.1x三个主要逻辑实体



无线局域网络安全协议

➤ IEEE 802.1x协议

➤ 802.1x三个主要逻辑实体

- 申请者系统：申请者是一个希望接入网络的实体，它向认证者请求对网络服务的访问，并对认证者的协议报文进行应答。对于WLAN来说，通常为装有802.1x客户端软件支持EAP的STA。
- 认证者系统：认证者控制申请者对网络的服务访问，并在认证过程中将请求者的认证请求转发到认证服务器，然后根据认证服务器的指示执行对申请者的授权，认证者通常为支持IEEE 802.1x协议的网络设备，如AP等。它有两个逻辑端口：受控端口和非受控端口。

无线局域网络安全协议

➤ IEEE 802.1x协议

➤ 802.1x三个主要逻辑实体

➤ 认证者系统

- 非受控端口 (Uncontrolled Port) : 非受控端口始终处于双联通状态, 主要用于传送与认证相关的数据帧。在WLAN中, 过滤所有的网络数据流, 只允许EAP帧通过; 在认证时, 用户通过非受控端口和AP交换数据, 若用户通过认证, 则AP为用户打开一个受控端口。
- 受控端口 (Controlled Port) : 受控端口只有在认证通过的状态下才打开, 用于传递网络资源与服务, 否则处于非授权状态而申请者无法访问认证系统提供的服务。

无线局域网络安全协议

➤ IEEE 802.1x协议

➤ 802.1x三个主要逻辑实体

● 认证服务器:

- 认证服务器通常为 *RADIUS* 服务器, 该服务器可以存储有关用户的信息。
- 认证服务器执行验证请求者身份的功能, 并指明请求者是或否通过验证允许其接入认证者的网络服务。

无线局域网络安全协议

➤ IEEE 802.1x协议

➤ 802.1x三个主要逻辑实体

● 认证服务器:

■ RADIUS (Remote Authentication Dial In User Service, 远程拨入用户认证服务) 是一套由IETF (国际互联网工程任务组) 颁布的协议规范, 是IEEE802.1x体系的认证和授权处理部分中必不可少的后台服务器。

无线局域网络安全协议

➤ IEEE 802.1x协议

➤ 802.1x三个主要逻辑实体

- 认证服务器：

- EAP

- ❖ 上世纪90年代后期，为了解决无线局域网（WLAN）接入控制的问题（包括安全问题，信息资源盗用的问题），IEEE提出了802.1x协议族，采用基于端口的控制方法来实现接入端认证。
- ❖ 由于802.1x的成功，有线接入的局域网也开始广泛使用该协议来进行接入认证和计费。

无线局域网络安全协议

➤ IEEE 802.1x协议

➤ 802.1x三个主要逻辑实体

- 认证服务器：

- EAP

- ❖ EAP最早是用于点到点传输的扩展认证协议，它本身并不提供认证功能，而只是提供了一种客户端同认证服务器之间的信息交换协议。
- ❖ 认证服务器（通常为AP或者是接入交换机）本身的认证功能是通过后台的RADIUS服务器来完成。

无线局域网络安全协议

- ❖ IEEE 802.1x协议
 - ❖ 802.1x三个主要逻辑实体
 - ❖ 认证服务器：
 - ❖ EAP认证的过程包括：
 - ❖ 1. 认证请求端（supplicant）发起认证请求
 - ❖ 2. 认证服务器向认证请求端发出CODE为IDENTITY的身份请求
 - ❖ 3. 认证请求端响应请求,并发送用户名

无线局域网络安全协议

- ❖ IEEE 802.1x协议
 - ❖ 802.1x三个主要逻辑实体
 - ❖ 认证服务器：
 - ❖ EAP认证的过程包括：
 - ❖ 4. 认证服务器向认证请求端发出CODE为MD5CHALLENGE的认证请求
 - ❖ 5. 认证请求端响应请求,并发送加密后的认证密码(通常采用MD5加密)
 - ❖ 6. RADIUS服务器认证后,通过认证服务器转发成功或者失败的报文, 如果是成功报文,认证服务器会同时打开认证请求端口。

无线局域网络安全协议

- ❖ IEEE 802.1x协议
 - ❖ 802.1x三个主要逻辑实体
 - ❖ 认证服务器:
 - ❖ EAP数据帧定义

```
typedef struct _EAP_FRAME{  
    unsigned char  desmac[6]; // 目的MAC(会话发起时是多播地址)  
    unsigned char  soumac[6]; // 本地MAC  
    unsigned short type;      // 类型(EAP, 0x888E)  
    unsigned char  version;   // 协议版本(1)  
    unsigned char  ptype;     // EAP包类型  
    unsigned short length;    // EAP包长度  
    unsigned char  body[256]; // EAP包数据  
} EAP_FRAME, * PEAP_FRAME;
```

无线局域网络安全协议

- ❖ IEEE 802.1x协议
 - ❖ 802.1x三个主要逻辑实体
 - ❖ 认证服务器:
 - ❖ EAP数据包定义

Code	1
Identifier	2
Length	3-4
Authenticator	5-20
Attribute	21 - N

```
typedef struct _EAP_PACKET{  
    unsigned char  code;           // CODE域  
    unsigned char  identifier;     // IDENTIFIER域  
    unsigned short length;         // 长度  
    unsigned char  type;           // 类型(IDENTITY,NOTIFICATION,  
                                   // NAK,MD5-CHANLLENGE,ONE-TIME)  
    unsigned char  data[256];     // 数据域  
}EAP_PACKET, * PEAP_PACKET;
```

无线局域网络安全协议

❖ IEEE 802.1x协议

❖ 特点

❖ IEEE 802.1X协议能很好地适应现代网络用户数量急剧增加和业务多样性的要求，与传统的PPPoE（Point-to-Point Protocol over Ethernet）和Web/Protal认证方式相比，具有以下优势：

❖ 协议实现简单

❖ IEEE 802.1X协议为两层协议，不需要到达第三层对设备的整体性能要求不高，可以有效降低建网成本。

❖ 业务灵活

❖ IEEE 802.1X的认证体系结构中采用了“控制端口”和“非控制端口”的逻辑功能，从而可以实现业务与认证的分离。

❖ 成本低

❖ IEEE 802.1X协议解决了传统的PPPoE和Web/Protal认证方式带来的问题，消除了网络瓶颈，减轻了网络封装开销，降低了建网成本。

无线局域网络安全协议

❖ IEEE 802.1x协议

❖ 特点

❖ IEEE 802.1X协议优势：

❖ 安全可靠

- ❖ 用户身份识别取决于用户名，而不是MAC地址，从而可以实现基于用户的认证、授权和计费。
- ❖ 支持可扩展的认证、无口令认证，如公钥证书和智能卡、互联网密钥交换协议（IKE）、生物测定学、信用卡等，同时也支持口令认证。
- ❖ 动态密钥生成保证每次会话密钥各不相同，并且不必存储于NIC和AP中。
- ❖ 全局密钥（Global Key）可以在会话密钥的加密下安全地从接入点传给用户。
- ❖ 相互认证有效防止了中间人攻击和假冒接入点AP，还可以防范地址欺骗攻击、目标识别和拒绝服务攻击等。
- ❖ 可以在不改变网络接口卡的情况下，插入新的认证和密钥管理方法。

无线局域网络安全协议

❖ WPA协议

❖ 3种保密机制：

- ❖ TKIP（暂时密钥完整性协议）
- ❖ WRAP（无线增强认证协议）被802工作组舍弃（不介绍）
- ❖ CCMP（计数器模式密码块链消息完整码协议）

无线局域网络安全协议

- ❖ WPA协议

- ❖ 3种保密机制:

- ❖ TKIP（暂时密钥完整性协议）

- ❖ 暂时密钥完整性协议是用来加强WEP设备上的WEP协议的密码套件，是为了解决WEP协议存在的问题，同时又要使WEP设备能够通过软件升级来支持TKIP（既要保持兼容，又要解决WEP的安全缺陷）

无线局域网络安全协议

❖ WPA协议

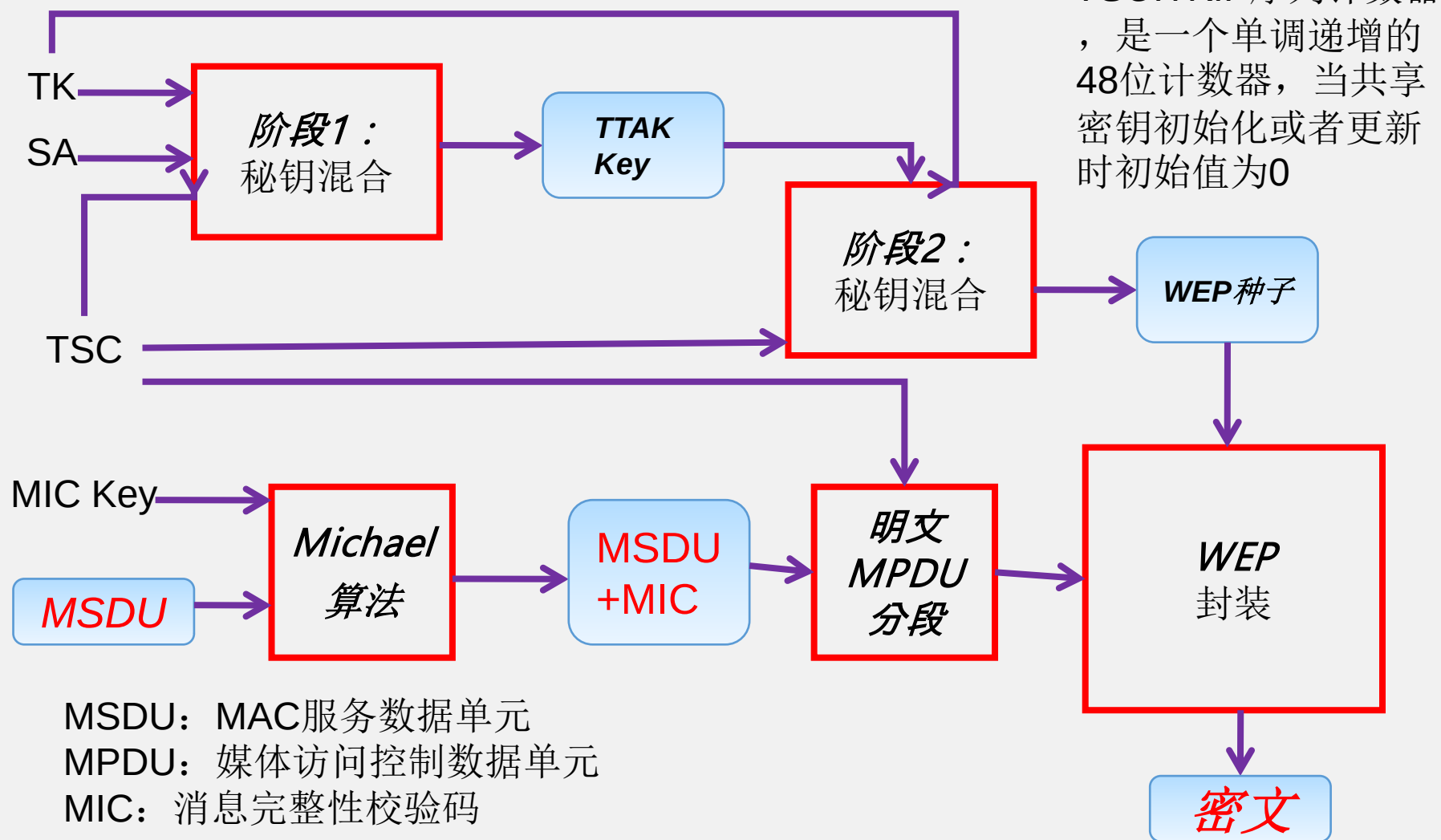
❖ TKIP（暂时密钥完整性协议）

❖ 设计TKIP的限制：

- ❖ 对WEP设备更换部分芯片还不如更换整个设备，所以升级必须是软件的
 - ❖ 许多WEP设备的CPU负荷已经很高，正常的通信已经使用了CPU90%的能力，所以TKIP引入负荷要尽量小
 - ❖ 许多WEP设备使用硬件实现RC4来降低CPU负荷，TKIP要适应这种做法
- ❖ 因此，TKIP是包裹在WEP外面的一套算法，希望能在上述限制下达到最好的安全性，它添加了以下4个算法：
- ❖ 采用密码学上的消息完整码（MIC）来防止数据被篡改
 - ❖ 采用新的IV序列规则来防止重放攻击
 - ❖ 采用新的per-packet key生成算法以防止弱密钥的产生
 - ❖ 采用Rekeying机制以生成新的加密和完整性密钥，防止IV重用

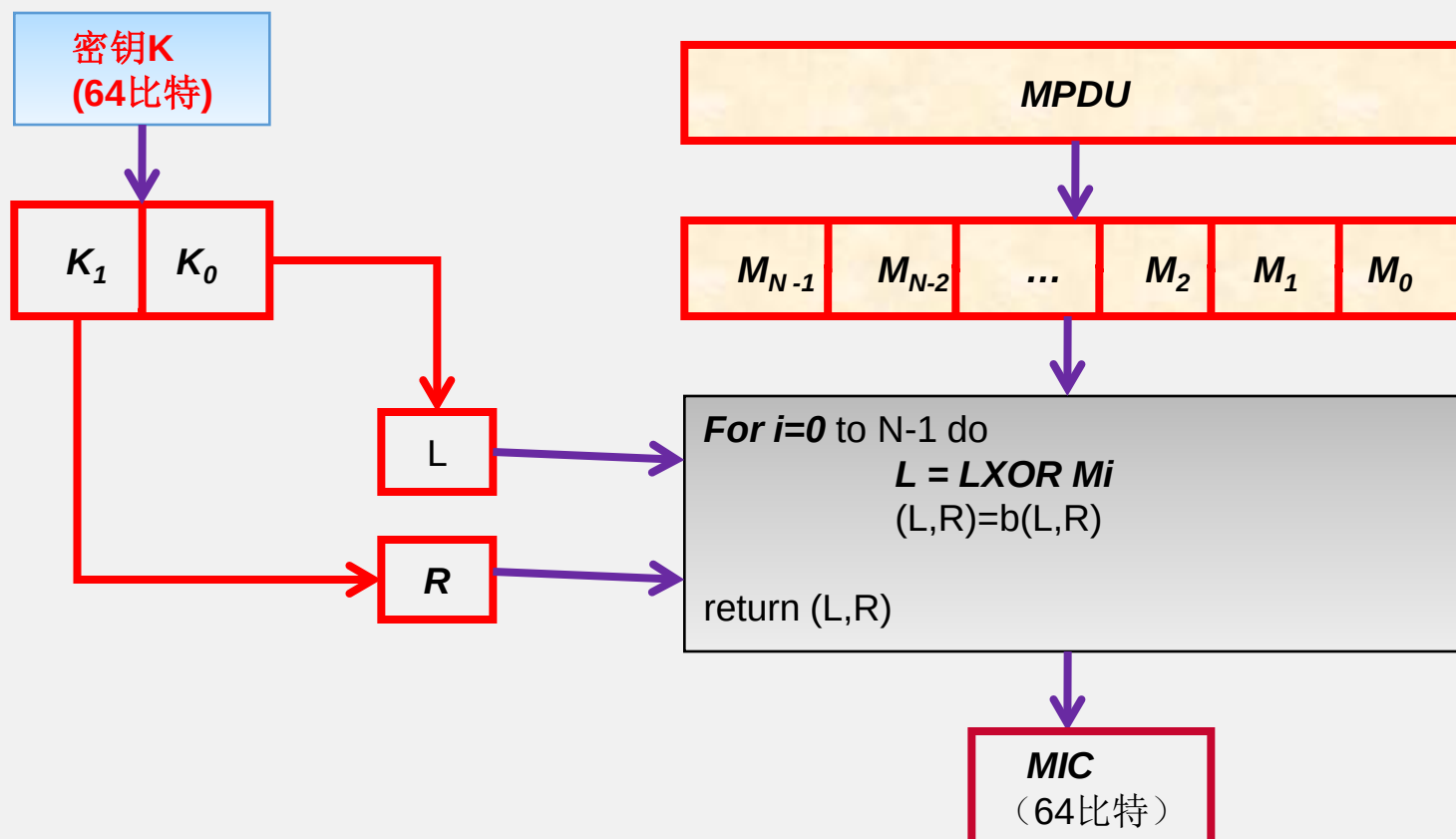
无线局域网络安全协议

TKIP的加密过程:



无线局域网络安全协议

Michael算法



无线局域网络安全协议

- ❖ WPA协议

- ❖ TKIP（暂时密钥完整性协议）

- ❖ Michael算法

- ❖ 加密时，TKIP根据上述字段计算MIC，并把MIC添加到明文MSDU后面
 - ❖ 如果MSDU加上MIC的长度超过了MAC帧的最大长度，TKIP把MSDU分段得到多个MPDU

无线局域网络安全协议

❖ WPA协议

❖ TKIP（暂时密钥完整性协议）

❖ Michael算法的安全性

❖ Michael算法输出64位的MIC，但设计安全性只有20位的安全强度，即攻击者伪造一个包仅需要尝试 $2^{20}-1$ 个包就能实现，理论上：

❖ 802.11b：攻击者可维持 2^{12} 包/s，即在 $2^{20}-1-12$ s后可成功

❖ 802.11a：攻击者可维持 2^{13} 包/s，即在26s后可成功

❖ Michael算法需要采取附加措施增强安全性--窗口

❖ 如果窗口为n，则TKIP每秒最多允许n-1个错误；一旦一秒内出现n个以上错误，TKIP就认为受到攻击，则延迟60s后重新协商相关的加密密钥

无线局域网络安全协议

- ❖ WPA协议
 - ❖ TKIP（暂时密钥完整性协议）
 - ❖ IV序列
 - ❖ 可以防止重放攻击
 - ❖ 把数据包的序列号和MIC密钥联系起来，数据包序列号空间耗尽以前重新生成MIC密钥
 - ❖ TKIP使用WEP IV作为包序列号TSC，并且在TKIP中延长为48位

无线局域网络安全协议

❖ WPA协议

❖ TKIP（暂时密钥完整性协议）

❖ IV序列

❖ IV不能重复

- ❖ 在WEP中，RC4重用密钥会导致安全问题，因此数据包密钥还有赖于在相同的TK（Temporal Key）下，IV不能重复
- ❖ IV在TK初始化或更新时初始化为0，当IV达到最大时，数据停止传输或进行Rekeying
- ❖ 48位的IV可以支持248个包，MSDU最大为2304字节，IP网络中最大（MTU）为1500字节，还有ACK帧等，假设帧平均为512字节，在IEEE 802.11g 54Mbit/s下，一次会话大约需要645年才会使IV达到最大值

无线局域网络安全协议

- ❖ WPA协议
 - ❖ TKIP（暂时密钥完整性协议）
 - ❖ 与WEP协议的比较
 - ❖ TKIP修复WEP中的缺陷
 - ❖ 完整性：TKIP引进了一种新的完整性保护机制，使用Michael算法。Michael运行在服务数据单元层，可在设备驱动程序中实现。

无线局域网络安全协议

❖ WPA协议

❖ TKIP（暂时密钥完整性协议）

❖ 与WEP协议的比较

❖ TKIP修复WEP中的缺陷

❖ 检测重放攻击：

- ❖ TKIP使用新IV机制作为序列号。

- ❖ TSC（TKIP序列计数器）初始化后，每发送一个消息后自增。接收者记录最近接收消息的TSC。

- ❖ 如果最新接收消息的TSC值小于存储的最小TSC值，则接收者扔掉此消息；

- ❖ 如果TSC大于存储的最大TSC值，则保留此消息，并且更新其存储的TSC值，

- ❖ 如果刚收到消息的TSC值介于最大值和最小值之间，则接收者检查TSC是否已经存储；

- ❖ 如果有记录，则扔掉此消息；否则，保留此消息，并且存储新的TSC。

无线局域网络安全协议

❖ WPA协议

❖ TKIP（暂时密钥完整性协议）

❖ 与WEP协议的比较

❖ TKIP修复WEP中的缺陷

❖ 保密性

❖ WEP加密的主要问题为IV空间太小，并且没有考虑RC4中存在的弱密钥。为了克服第一个问题，在TKIP中，IV从24位增加至48位。由于WEP硬件仍然期望一个128位的WEP种子。因此48位IV与128位TK混合完后再压缩为128位。

❖ 对弱密钥问题，在TKIP中单包加密密钥都不相同。因此，攻击者不能观察到具有使用相同密钥的足够数量的消息。

无线局域网络安全协议

❖ WPA协议

❖ 3种保密机制：

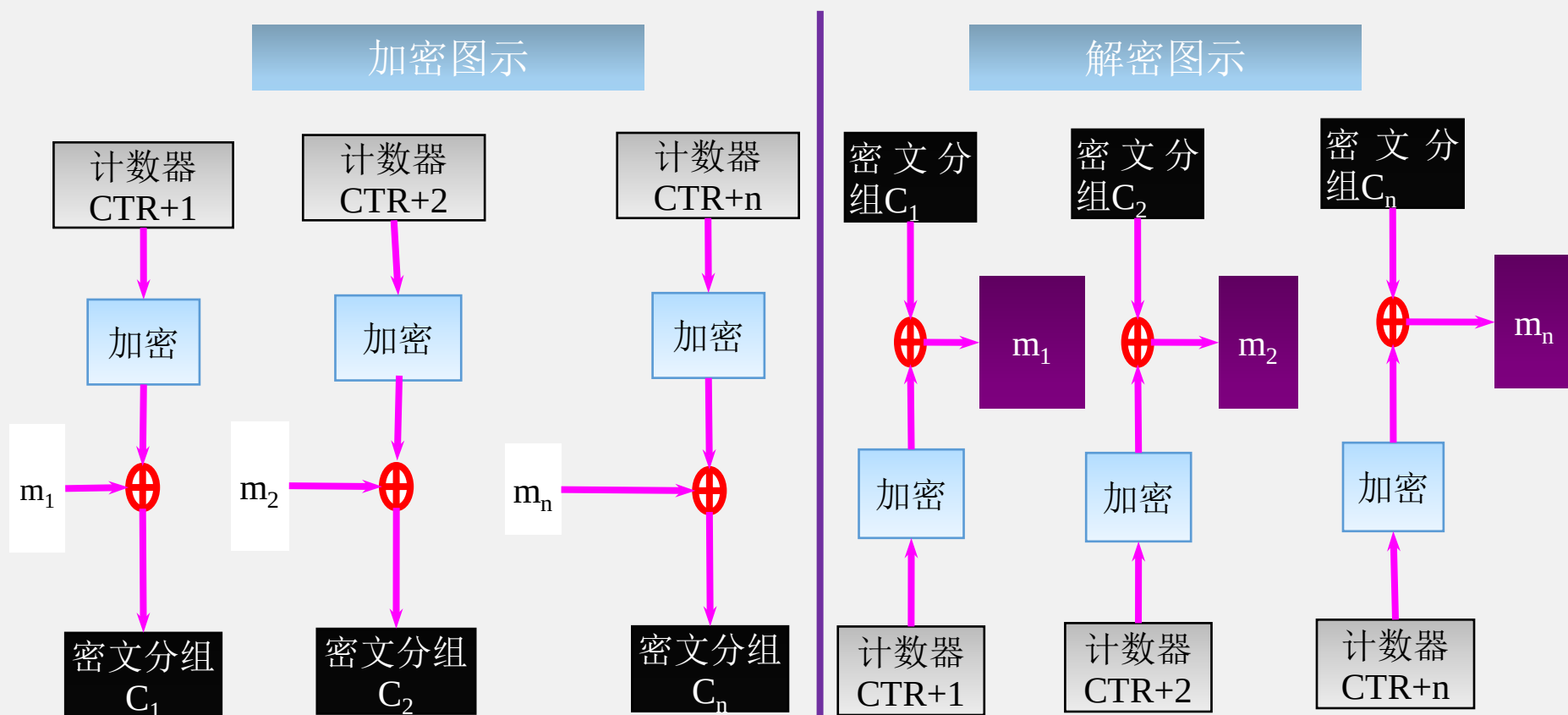
❖ CCMP（计数器模式密码块链消息完整码协议）

❖ 计数器模式（CTR）用于数据保密

❖ 加密块链接-消息认证码（Cipher Block Chaining Message Authentication Code, CBC-MAC）模式进行认证

无线局域网络安全协议

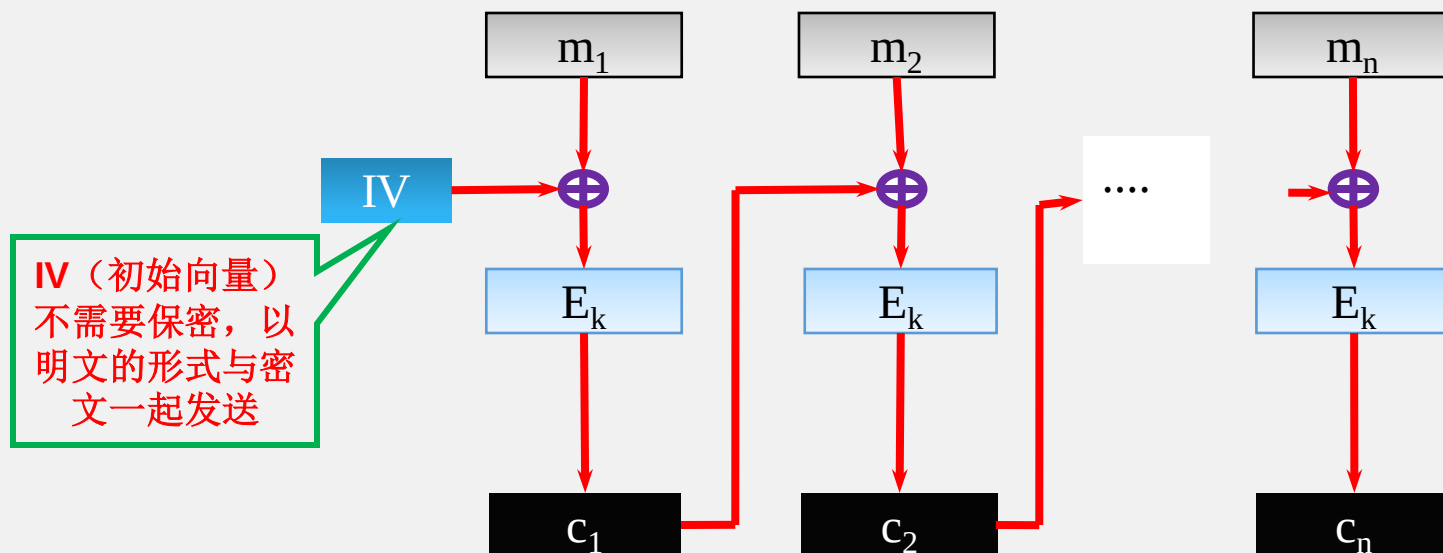
CTR模式



无线局域网络安全协议

CBC模式

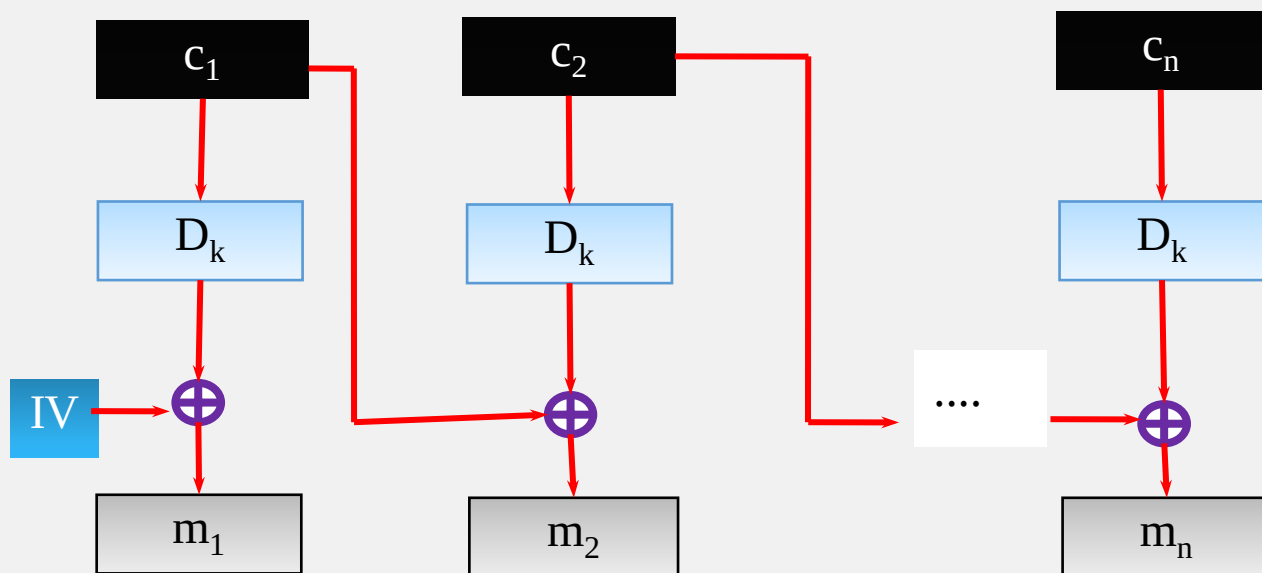
加密图示



加密: $c_1 = E_k(m_1 \text{ xor } IV)$, $c_i = E_k(m_i \text{ xor } c_{i-1})$ $i = 2, 3, 4, \dots, N$

无线局域网络安全协议

CBC模式



解密: $m_1 = D_k(c_1) \text{ xor } IV$, $m_i = D_k(c_i) \text{ xor } c_{i-1}$ $i=2, 3, 4, \dots, N$

无线局域网络安全协议

❖ WPA协议

❖ 3种保密机制：

❖ CCMP（计数器模式密码块链消息完整码协议）

- ❖ CCMP是基于AES的CCM模式，完全取代了原有WEP加密，能够解决WEP加密中的不足，可以为WLAN提供更好的加密、认证、完整性和抗重放攻击的能力，是IEEE 802.11i中强制要求实现的加密方式，同时也是IEEE针对WLAN安全的长远解决方案。

无线局域网络安全协议

❖ WPA协议

❖ CCMP（计数器模式密码块链消息完整码协议）

❖ 加密算法：

❖ 流密码RC4并不适合，应当采用分组密码，所以选择了AES（高级加密标准）：

- ❖ 不论是反馈模式还是非反馈模式，都非常适合于各种计算环境下的软硬件实现
- ❖ 密钥扩展方案优秀，密钥生成灵活
- ❖ 算法对内存要求低
- ❖ 是最抵抗能量和时间攻击的算法之一，而在提供保护能力的同时不对性能产生大的影响
- ❖ 分组和密钥的长度可变
- ❖ 执行的轮数可变

无线局域网络安全协议

❖ WPA协议

❖ CCMP（计数器模式密码块链消息完整码协议）

❖ 加密对象：

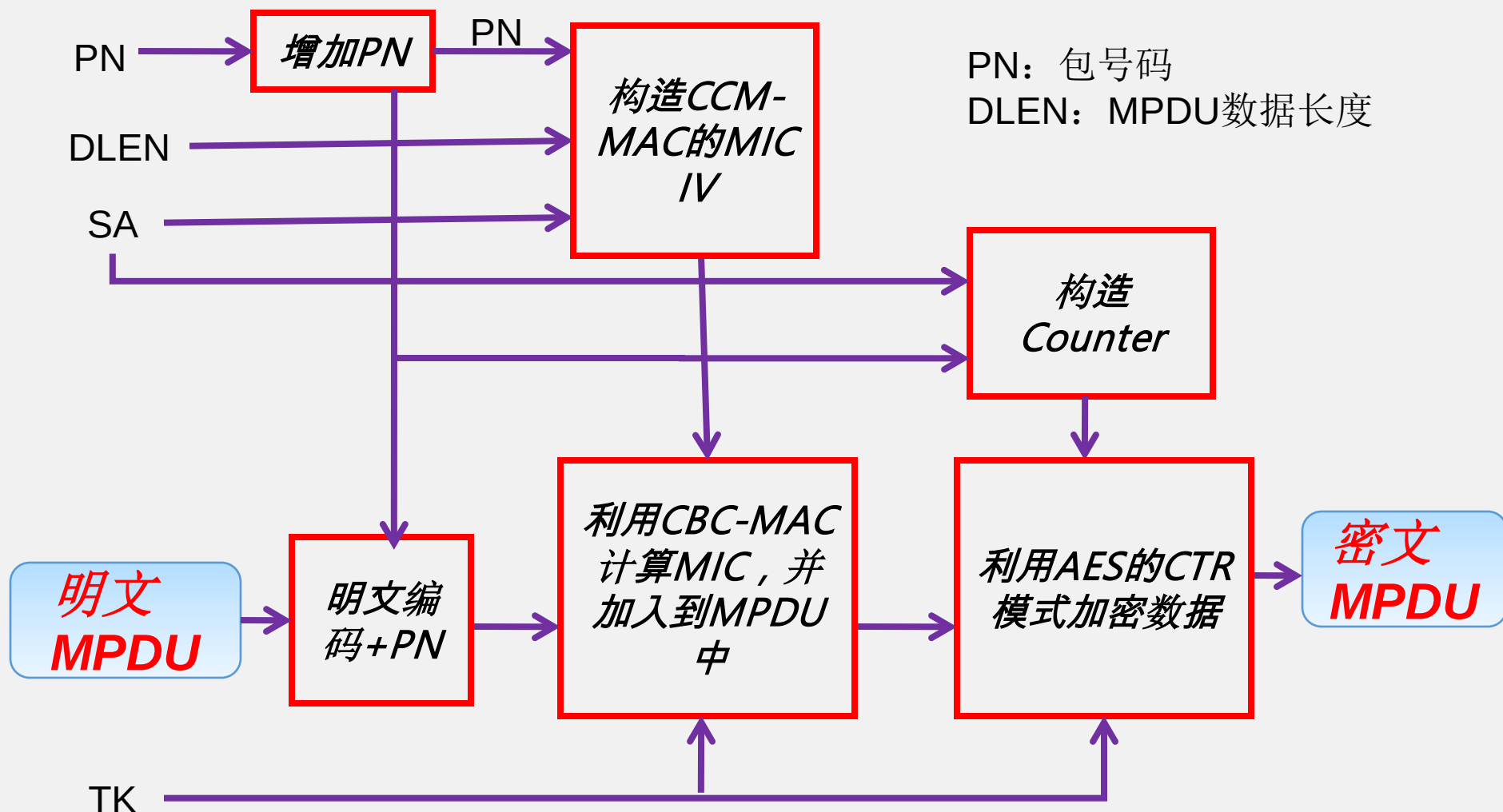
- ❖ CCMP的加密对象是MPDU，使用48位的包号码Packet Number（PN），PN用于产生CTR模式的Counter和CBC-MAC模式的IV

❖ 加密过程：

- ❖ 增加PN值，保证每个MPDU有一个新的PN，然后把PN编码为MPDU的一部分。
- ❖ 利用SA（发送方地址）、MPDU数据长度（DLEN）和PN构造IV。
- ❖ 使用该IV，计算MIC（取64位），添加到MPDU后面。
- ❖ 利用PN和SA构造CTR模式的Counter。
- ❖ 使用该Counter，使用AES加密MPDU数据和MIC。

无线局域网络安全协议

CCMP加密过程



无线局域网络安全协议

❖ WPA协议

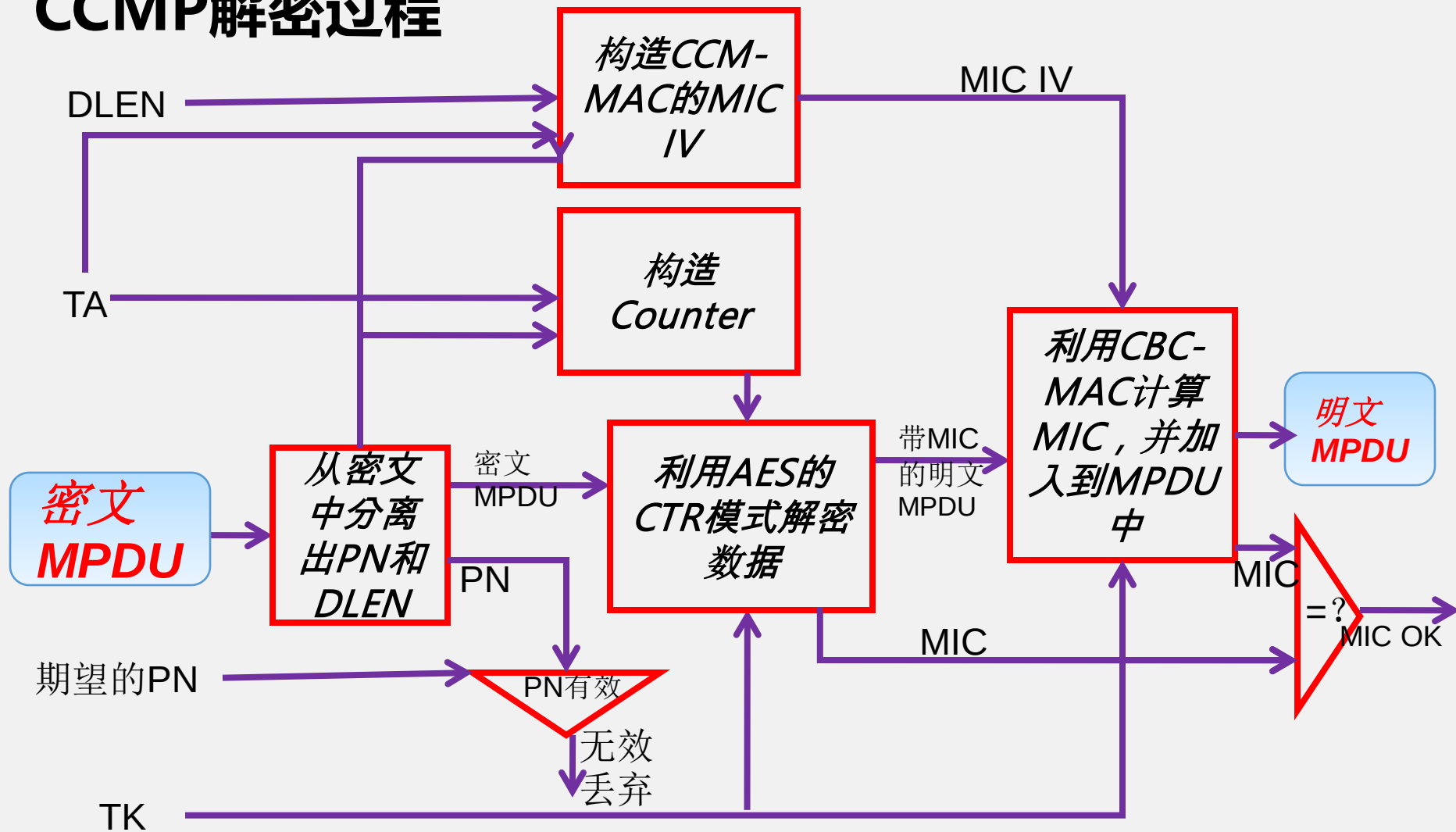
❖ CCMP（计数器模式密码块链消息完整码协议）

❖ 解密过程

- ❖ 从接收包中解出PN和DLEN
- ❖ 进行重放检测，如果PN在重放窗口之外，则丢弃该MPDU
- ❖ 利用PN和MPDU的SA构造CTR模式的Counter
- ❖ 利用该Counter，进行CTR模式解密，操作同加密一样
- ❖ 利用SA，MPDU数据长度DLEN和PN构造IV
- ❖ 使用该IV，CCMP在CCM-MAC下重新解密出MPDU的MIC'，比较MIC'和收到的MIC，如不匹配，丢弃该MPDU

无线局域网络安全协议

CCMP解密过程

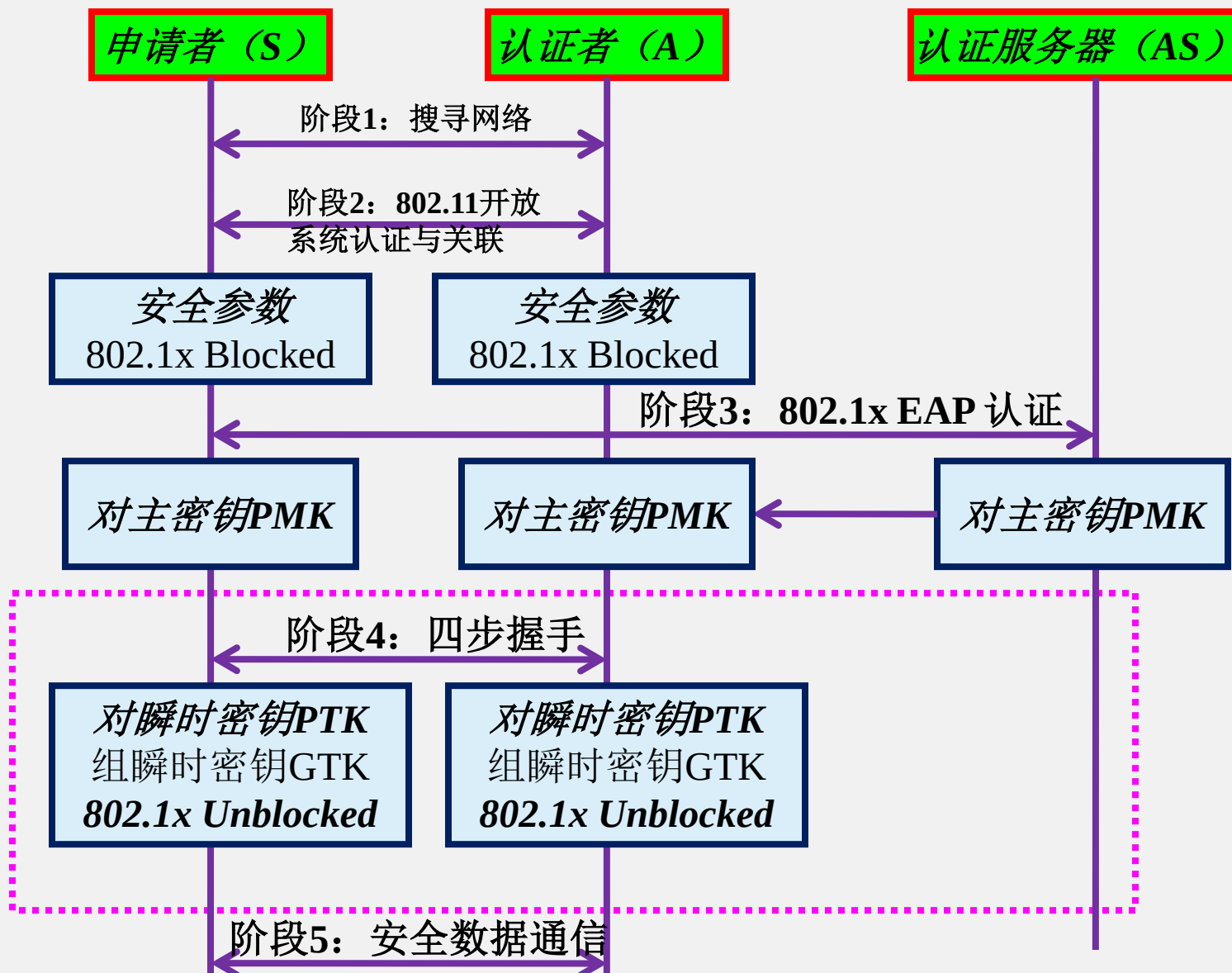


无线局域网络安全协议

❖ IEEE 802.11i协议

- ❖ IEEE 802工作组在2004年推出了IEEE 802.11i安全标准，该标准旨在为IEEE 802.11网络提供增强型介质访问控制安全方案。
- ❖ IEEE 802.11i提出了两套体系：强健安全网络（RSN）和预强健安全网络（Pre-RSN）。Pre-RSN主要是前向兼容，例如IEEE 802.11i需要支持的WEP、IEEE 802.1x等，我国主要是RSN。

无线局域网络安全协议



IEEE 802.11i 认证及密钥交换过程

无线局域网络安全协议

❖ IEEE 802.11i协议

❖ IEEE 802.11i接入协议

- ❖ 申请者在网络发现阶段发现网络接入设备及其具有的安全能力
- ❖ 申请者和认证者之间进行802.1x开放系统认证并通过关联请求和响应协商他们之间的密码组件。
- ❖ 由终端用户发出身份认证申请，AP启用认证流程。为了前向兼容，IEEE 802.1x采用开放系统认证，开放系统认证是缺省模式，无法提供真正意义上的安全防护，该阶段只负责完成初步认证流程，后续阶段会对认证进行补充和加强。
- ❖ 本阶段802.1x端口仍然没有打开，保持阻塞状态不能进行数据交换。
- ❖ 真正的802.1x EAP认证阶段在申请者和认证服务器之间进行
 - ❖ 双方进行安全的双向认证。认证服务器生成主密钥（MK）再由主密钥生成对主密钥（PMK）
 - ❖ 认证服务器要通过安全信道把PMK发送给认证者

无线局域网络安全协议

- ❖ IEEE 802.11i协议

- ❖ IEEE 802.11i接入协议

- ❖ 申请者和认证者进行四步握手

- ❖ IEEE 802.11i摒弃了以前安全架构的密钥单层次管理方式，改用密钥派生机制，分层管理密钥，上层密钥派生并保护下层密钥，有效提高密钥管理的安全性。

- ❖ IEEE 802.11i链路加密协议使用了成对密钥和组密钥。成对密钥由认证服务器生成，组密钥由AP动态生成。256bit PMK通过伪随机函数派生出成对临时密钥（PTK），成对临时密钥用于保护终端用户和AP之间的传输数据。128bit的组主密钥（GMK）派生出临时组密钥（GTK）。

无线局域网络安全协议

❖ IEEE 802.11i协议

❖ IEEE 802.11i接入协议

❖ 申请者和认证者进行四步握手

❖ 组密钥的四次握手流程已经对密钥握手完成了大部分工作，从而简化了协商流程。

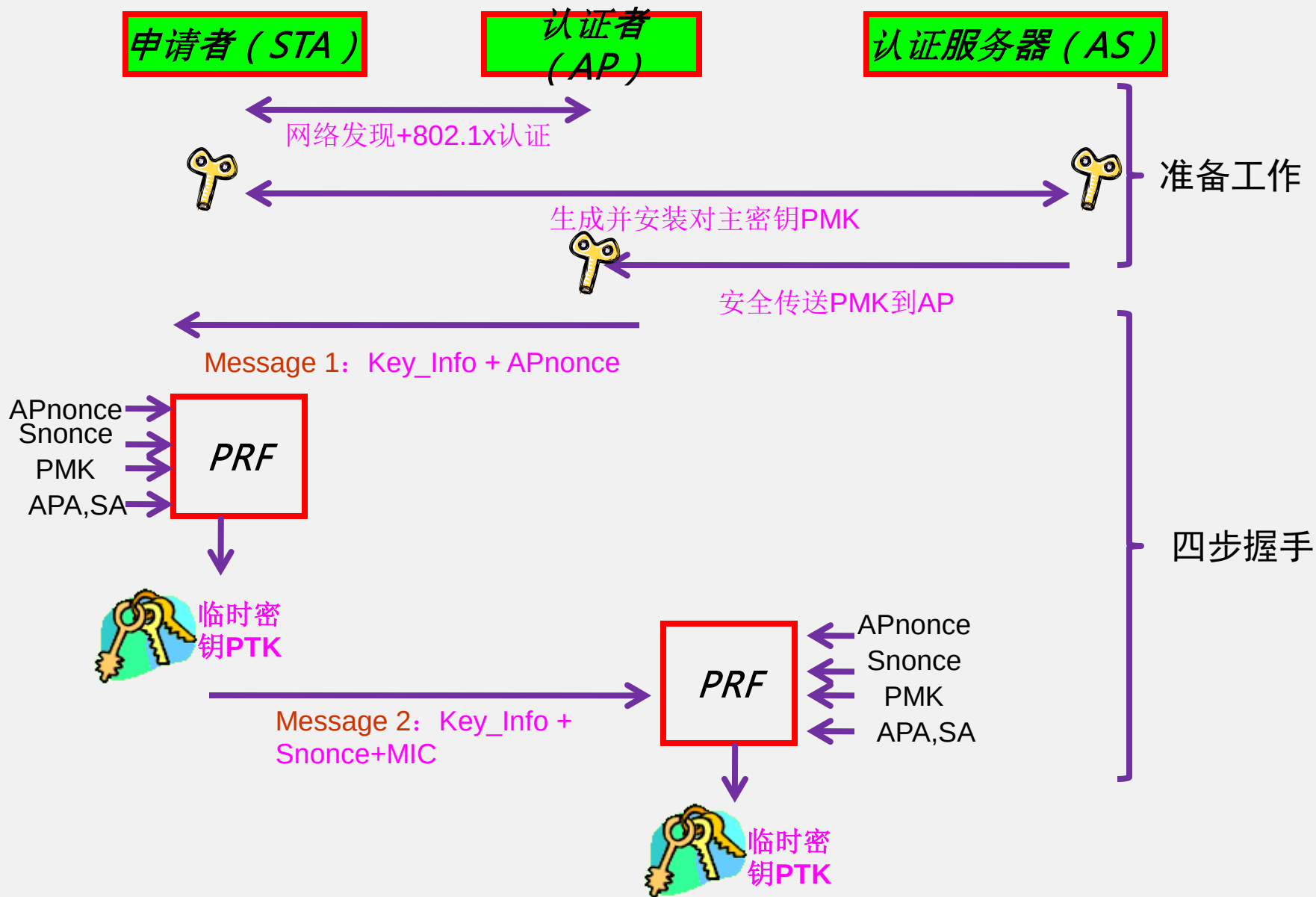
❖ 由AP生成新的随机数GTK nonce及新的GTK，GTK由nonce、AP的MAC地址、GMK共同生成。TKIP、CCMP的GTK有所不同，分别为256bit、128bit。AP发送消息至终端客户，该消息使用成对密钥加密保护。

❖ 终端收到消息后，向AP发送消息确认包，并且启用新的GTK。

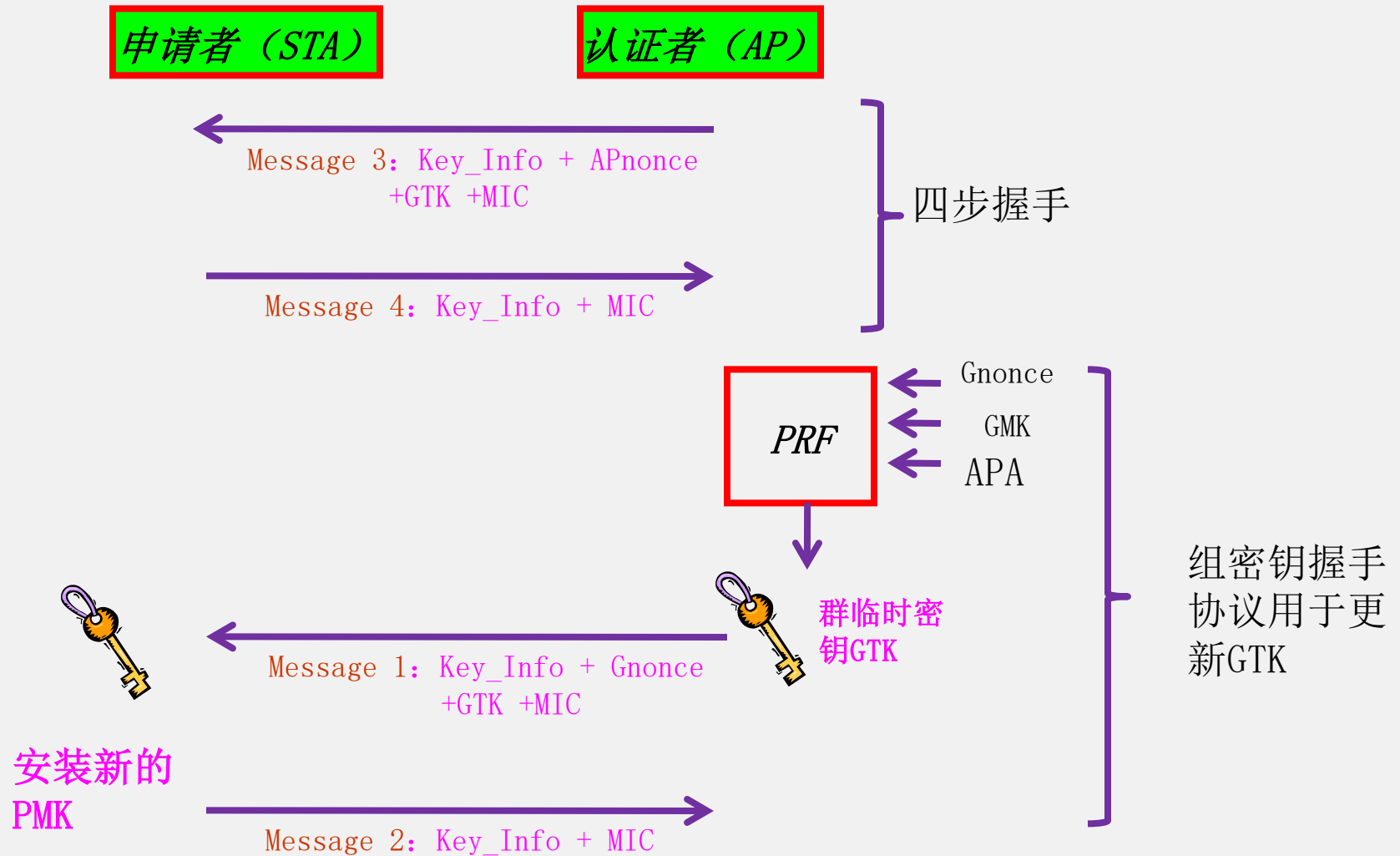
❖ 最后802.1x端口（受控端口）打开，在PTK、GTK和协商的密码组件的保护下，通过数据保密协议（如CCMP）进行安全的数据通信。

无线局域网网络安全协议

详细的四步握手过程



无线局域网络安全协议



无线局域网络安全协议

❖ IEEE 802.11i协议

❖ IEEE 802.11i接入协议

❖ 申请者和认证者进行四步握手

❖ 消息

- ❖ Message 1: AP发往STA的，消息中包含密钥信息和一个AP产生的随机数APnonce
 - ❖ STA检测通过后，产生一个随机数Snonce
 - ❖ STA将APnonce、Snonce、PMK、AP的MAC地址（APA）和STA的MAC地址（SA）输入一伪随机函数PRF，生成PTK；PTK的长度为512位，包含5部分：
 - ❖ 密钥确认密钥(Key Conformance Key, KCK)：0~127位，计算MIC（以提供四步握手和群密钥握手阶段的认证和完整性）
 - ❖ 密钥加密密钥（Key Encryption Key, KEK）：128~255位，用于四步握手和组密钥握手阶段的EAPoL帧加密密钥
 - ❖ 临时密钥（Temporal Key, TK）：256~383位，STA和AP之间的普通数据加密密钥
 - ❖ 计算发送报文的MIC密钥（64比特）
 - ❖ 计算接收报文的MIC密钥（64比特）

无线局域网络安全协议

- ❖ IEEE 802.11i协议

- ❖ IEEE 802.11i接入协议

- ❖ 申请者和认证者进行四步握手

- ❖ 消息

- ❖ Message 2: STA发往AP的，消息中包含Snonce和MIC等密钥信息

- ❖ AP收到消息后，同样的方式验证并计算PTK，AP利用PTK中的KCK计算MIC并与接收到的MIC比较，如果通过验证，则构造消息3

- ❖ Message 3: AP发往STA的，消息中包含APnonce和MIC等密钥信息；如果同时要进行GTK协商，消息3中也可能包括GTK信息

- ❖ STA收到消息后，如果通过验证，则构造消息4

- ❖ Message 4: 消息中只包含MIC和密钥信息

无线局域网络安全协议

- ❖ IEEE 802.11i协议
 - ❖ IEEE 802.11i接入协议
 - ❖ 申请者和认证者进行四步握手
 - ❖ 四步握手成功以后，AP还要生成一个256位的群组加密密钥（Group Transient Key, GTK）：
 - ❖ 所有与AP建立关联的STA均使用相同的GTK来发送广播消息
 - ❖ AP用该GTK来加密所有与之建立关联的STA的通信报文，STA则用GTK来解密由AP发送的报文并检验MIC

无线局域网络安全协议

❖ WAPI协议

- ❖ 我国在2003年5月就提出了无线局域网国家标准GB 15629.11，包含全新的无线局域网认证和保密基础结构（WLAN Authentication and Privacy Infrastructure，WAPI）安全机制。由两部分组成：
 - ❖ WAI（WLAN Authentication Infrastructure）：身份认证
 - ❖ WPI（WLAN Privacy Infrastructure）：对传输的数据加密（WPI由国家密码管理办公室提供，其算法是非公开的）

无线局域网络安全协议

❖ WAPI协议

❖ WAPI的认证服务WAI:

- ❖ WAPI沿用了成熟的IEEE 802.1x认证的基本体系，定义了移动终端（MT）、接入点AP、认证服务单元（ASU）等实体，其中ASU对应于IEEE 802.1x体系的认证服务器。
- ❖ WAPI认证实现了双向认证机制，要求移动终端和接入点都需要通过身份验证，有效防范中间人攻击。
- ❖ WAI认证机制赋予ASU授权的权利，ASU作为可信任的第三方，统一管理全网数字证书。

无线局域网络安全协议

❖ WAPI协议

❖ WAPI的认证服务WAI:

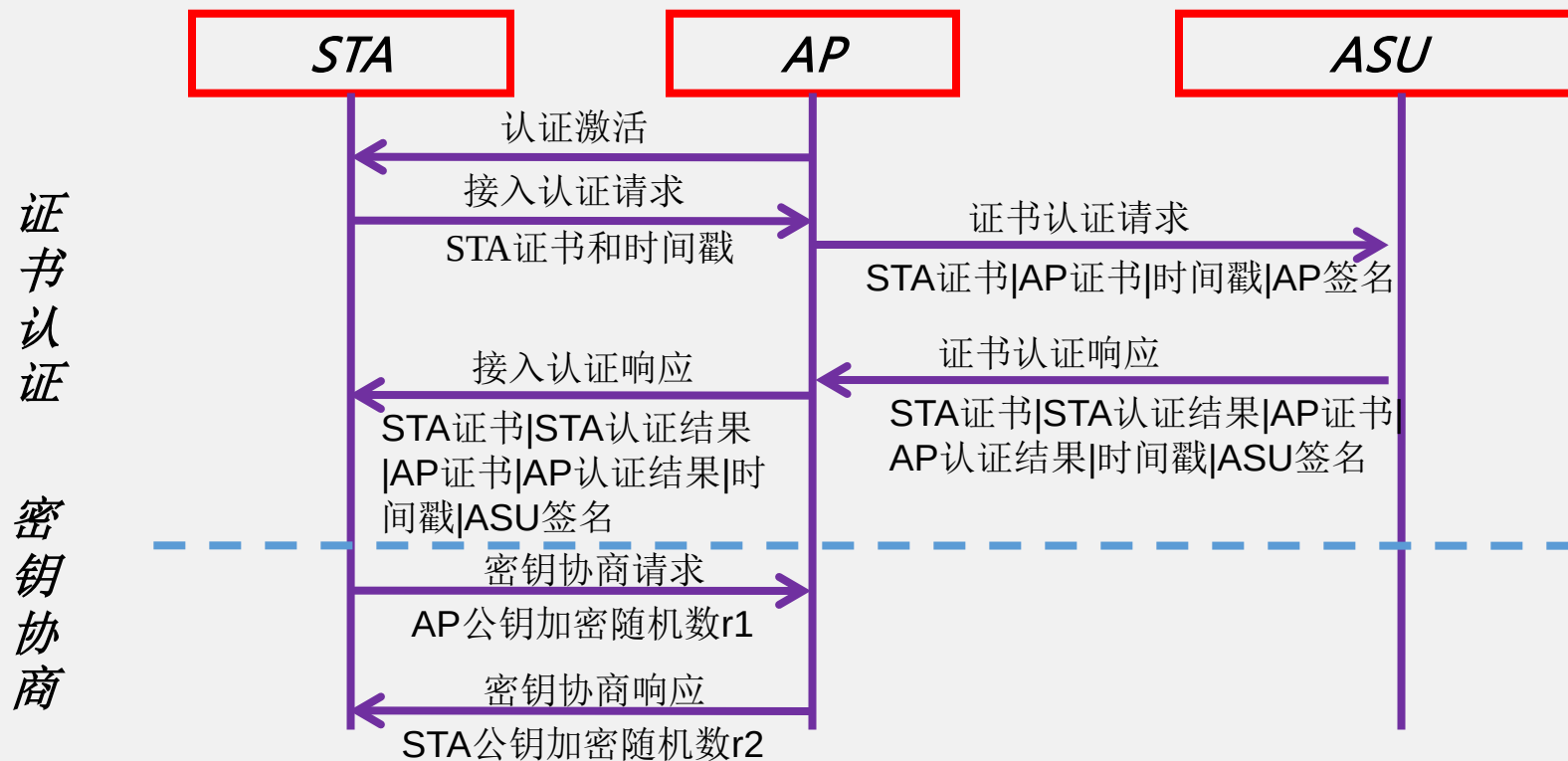
- ❖ AP提供两种访问WLAN的逻辑通道，定义为两类端口，即受控端口和非受控端口。AP提供STA连接到认证服务单元（ASU）的端口（即非受控端口），确保只有通过认证的STA才能使用AP提供的数据端口（即受控端口）访问网络。在基于端口的接入控制操作中，定义了3个实体：
 - ❖ 认证器实体（Authenticator Entity，AE）：为认证请求者在接入服务之前提供认证操作的实体，驻留在AP中
 - ❖ 认证请求者实体（Authentication SUppliant Entity ASUE）：需通过认证服务单元进行认证的实体，驻留在STA中
 - ❖ 认证服务实体（Authentication Service Entity，ASE）：为认证器和认证请求提供相互认证的实体，驻留在ASU中

无线局域网络安全协议

❖ WAPI协议

❖ WAPI的认证服务WAI:

- ❖ 当STA关联或者重新关联至AP时，必须进行相互身份认证。
整个认证过程包括证书认证与会话密钥协商两部分



无线局域网络安全协议

❖ WAPI协议

❖ WAPI的认证服务WAI:

❖ 证书认证过程

- ❖ 认证激活：当STA关联或重新关联时，AP向STA发送认证激活以启动整个认证过程
- ❖ 接入认证请求：STA将其证书和当前系统时间（接入认证请求时间）发送给AP
- ❖ 证书认证请求：AP收到STA请求后，首先记录认证请求时间，然后将STA证书、接入认证请求时间、AP证书以及AP的私钥对他们的签名发送给ASU

无线局域网络安全协议

❖ WAPI协议

❖ WAPI的认证服务WAI:

❖ 证书认证过程

- ❖ 证书认证响应：ASU验证AP的签名和AP证书的有效性
 - ❖ 若不正确，认证过程失败
 - ❖ 进一步验证STA证书。验证完毕后，ASU将STA与AP证书认证结果信息和ASU对它们的签名发送给AP
- ❖ 接入认证响应：AP对ASU返回的证书进行验证，得到STA证书的认证结果，根据此结果对STA进行接入控制。AP将收到的证书认证响应回送给STA，STA验证ASU的签名后，得到AP证书的验证结果，并据此决定是否接入AP

无线局域网络安全协议

❖ WAPI协议

❖ WAPI的认证服务WAI:

❖ 会话密钥协商

❖ 密钥协商请求：STA产生一串随机数据，利用AP的公钥加密后，向AP发送密钥协商请求。此请求包含请求方所有的备选会话密钥算法

❖ 密钥协商响应：

❖ AP收到STA发送来的请求后，首先进行会话算法协商，若响应方不支持请求方的所有备选会话算法，则响应会话算法协商失败；

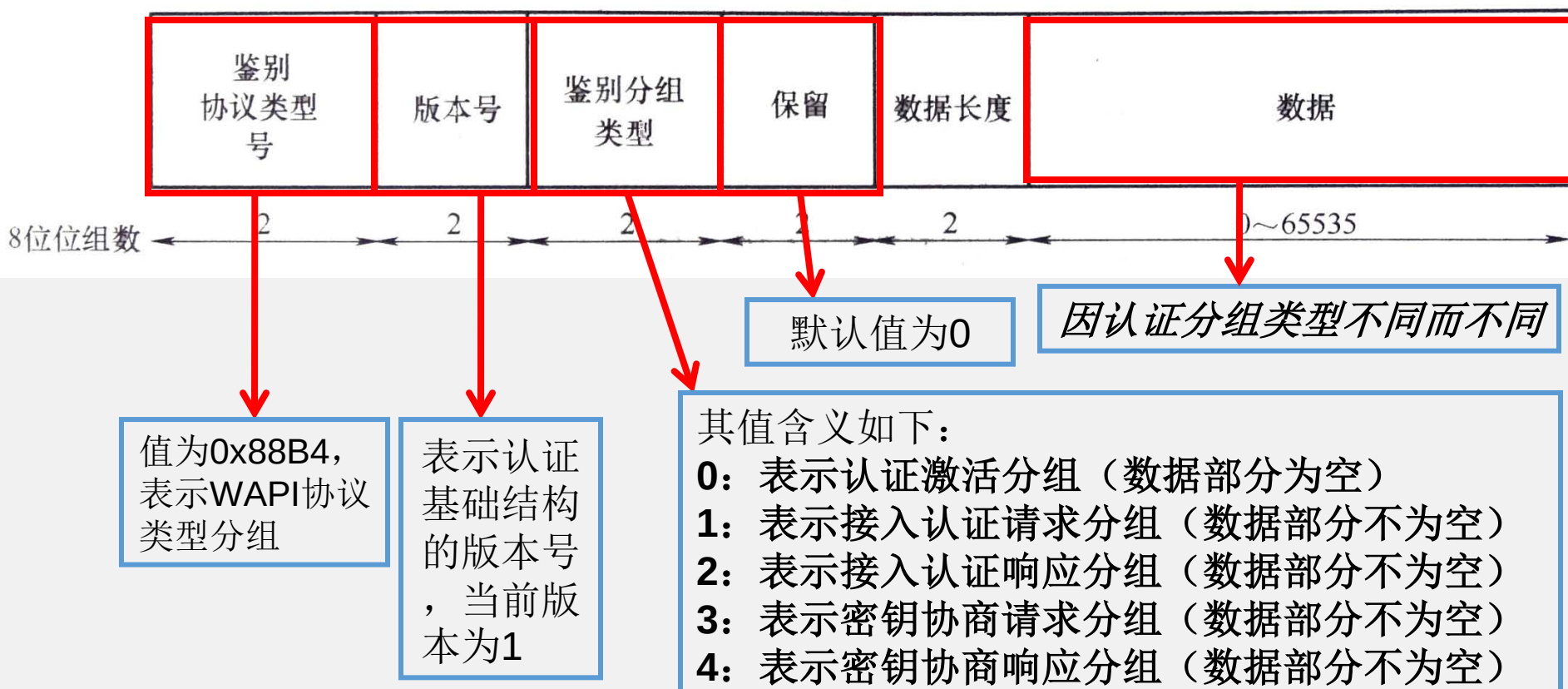
❖ 否则，选择一种自己支持的算法，再利用私钥解密协商数据，得到STA的随机数据，然后产生一串随机数，利用STA的公钥加密后，发送给STA。协商成功后，双方将自己与对方的随机数进行运算生成会话密钥

无线局域网络安全协议

❖ WAPI协议

❖ WAPI的认证服务WAI的数据格式

❖ STA与AP之间的认证数据格式



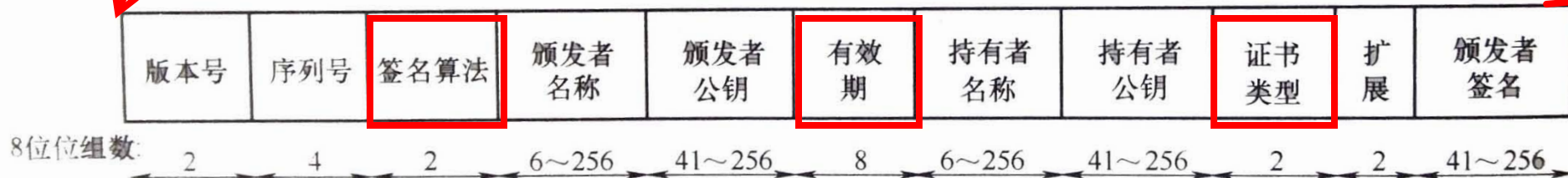
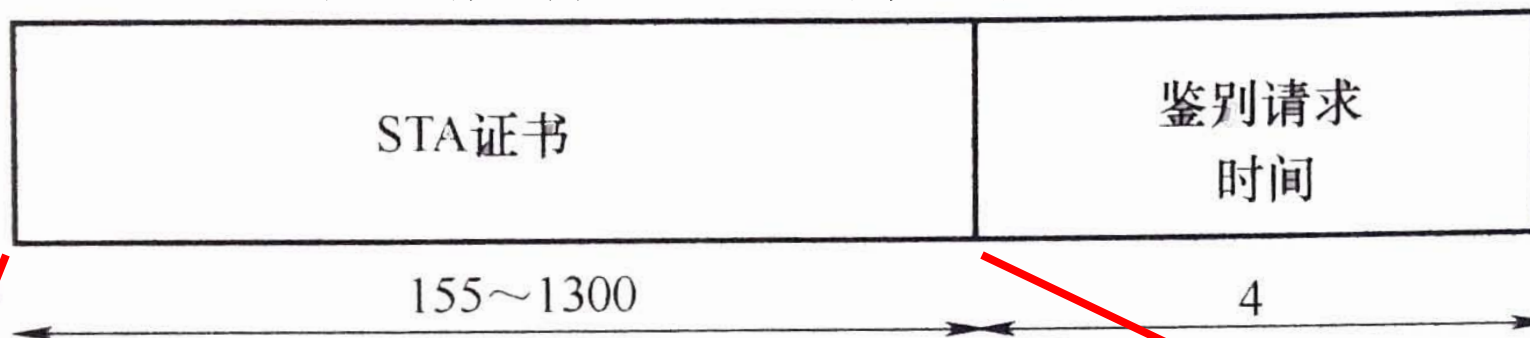
无线局域网络安全协议

❖ WAPI协议

❖ WAPI的认证服务WAI的数据格式

❖ STA与AP之间的认证数据格式

❖ 接入认证请求分组（1）的数据段格式



无线局域网络安全协议

❖ WAPI协议

❖ WAPI的认证服务WAI的数据格式

❖ STA与AP之间的认证数据格式

❖ 接入认证请求分组的数据段格式

❖ 签名算法字段（2字节）

❖ Hash算法标识其值含义：

- ❖ 1：表示国家密码管理委员会办公室批准的用于WLAN的散列函数算法；其他值保留

❖ 签名算法标识其值含义：

- ❖ 1：192位的椭圆曲线算法；
- ❖ 2：224位的椭圆曲线算法；
- ❖ 3：256位的椭圆曲线算法；
- ❖ 其他值保留

Hash算法标识（1字节）

签名算法标识（1字节）

无线局域网络安全协议

❖ WAPI协议

❖ WAPI的认证服务WAI的数据格式

❖ STA与AP之间的认证数据格式

❖ 接入认证请求分组的数据段格式

❖ 有效期字段（8个字节）

❖ 起始日期与截止日期均为4个8位位组，表示1970年1月1日0时起到当前时间的毫秒数计数值

❖ 证书类型字段为2个8位位组，标识证书应用的设备类型

❖ 0: STA证书

❖ 1: AP证书

❖ 2: ASU证书

❖ 其他值保留

起始时间
(4字节)

截止时间
(4字节)

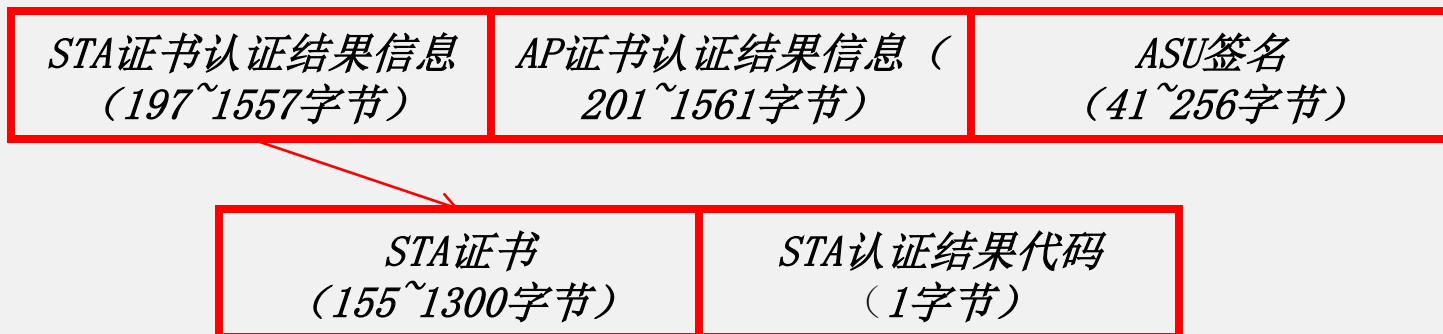
无线局域网络安全协议

❖ WAPI协议

❖ WAPI的认证服务WAI的数据格式

❖ STA与AP之间的认证数据格式

❖ 接入认证响应分组（2）的数据段格式（AP发往STA）



❖ STA证书认证结果代码字段表示ASU对证书的认证结果，

- ❖ “0”：证书有效
- ❖ “1”：证书未启用
- ❖ “2”：证书已经过期
- ❖ “3”：证书的颁发者不明确
- ❖ “4”：签名错误
- ❖ 其他值保留

无线局域网络安全协议

❖ WAPI协议

❖ WAPI的认证服务WAI的数据格式

❖ STA与AP之间的认证数据格式

❖ 接入认证响应分组的数据段格式（AP发往STA）

AP证书 (155~1300字节)	AP证书认证结果代码 (1字节)	认证请求时间 (4字节)
----------------------	---------------------	-----------------

❖ AP证书认证结果信息字段定义

❖ AP证书字段定义同STA证书

❖ AP证书认证结果代码定义同STA证书认证结果代码定义

❖ ASU签名表示ASU对STA和AP证书认证结果信息签名

无线局域网络安全协议

❖ WAPI协议

❖ WAPI的认证服务WAI的数据格式

❖ STA与AP之间的认证数据格式

❖ 密钥协商请求分组（3）的数据段格式

密钥协商数据 (17~256字节)	备选会话算法个数（ 1字节）	备选算法标识 (1~255字节)
----------------------	-------------------	---------------------

- ❖ **密钥协商数据**字段由长度字段与相应内容组成，长度字段为1个8位位组；数据协商数据是一串用对方公钥加密后的随机数据
- ❖ **备选会话算法个数**为1个8位位组，表示密钥协商请求方支持的会话算法的个数，该字段默认为1，即仅支持国家密码管理委员会办公室批准的用于WLAN的对称密码算法，当前支持的有：
 - ❖ 0：不加密
 - ❖ 1：国家密码管理委员会办公室批准的用于WLAN的对称密码算法
 - ❖ 其他值保留

无线局域网络安全协议

❖ WAPI协议

❖ WAPI的认证服务WAI的数据格式

❖ STA与AP之间的认证数据格式

❖ 密钥协商响应分组（3）的数据段格式

会话算法协商响应 标识（1字节）	密钥协商数据（17~256字节）
---------------------	------------------

❖ 会话算法协商响应标识：1个8位位组

❖ 0：表示会话算法协商失败

❖ 其他值为响应方从请求方的备选算法中选择的加密算法标识

❖ 密钥协商数据字段同请求分组相同。若会话算法协商失败，此字段为空

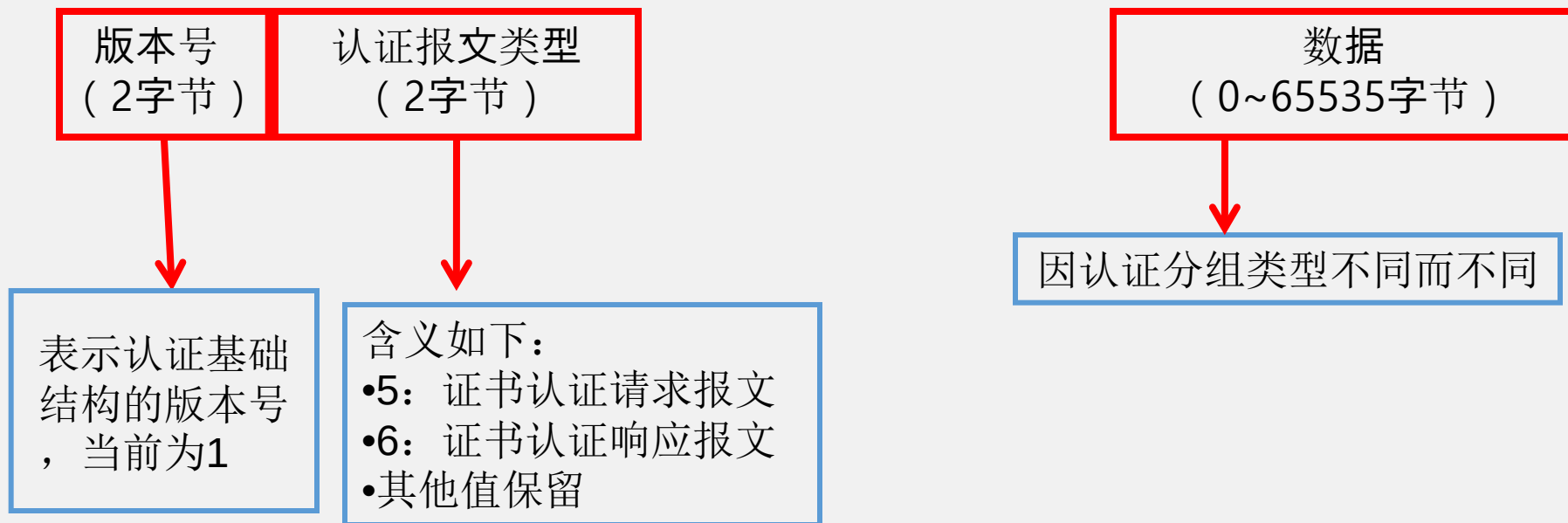
无线局域网络安全协议

❖ WAPI协议

❖ WAPI的认证服务WAI的数据格式

❖ AP与ASU之间的认证报文

❖ AP与ASU之间的通行采用UDP套接口



无线局域网络安全协议

❖ WAPI协议

❖ WAPI的认证服务WAI的数据格式

❖ AP与ASU之间的认证报文

❖ 证书认证请求报文：

STA证书 (155~1300字节)	AP证书 (155~1300字节)	认证请求时间 (4字节)	AP签名 (41~256字节)
-----------------------	-----------------------	-----------------	--------------------

❖ 证书认证响应报文：

STA证书认证结果信息 (197~1557字节)	AP证书认证结果信息 (201~1561字节)	ASU签名 (41~256字节)
-----------------------------	--------------------------	---------------------

❖ 注：各个字段同STA与AP之间报文相应字段

无线局域网络安全协议

- ❖ WAPI协议

- ❖ WAPI的修正

- ❖ 考虑到不同WLAN安全解决方案(如IEEE 802.11i)的并存，2006年7月，中国宽带无线IP标准工作组(BWIPS)公布新的国家标准GB 15629.11-2003/XG1-2006(WAPI-XG1)，对原有标准进行了修正，提出了新的WLAN安全解决方案

无线局域网络安全协议

➤ WAPI协议

✓ 新安全方案的组成：

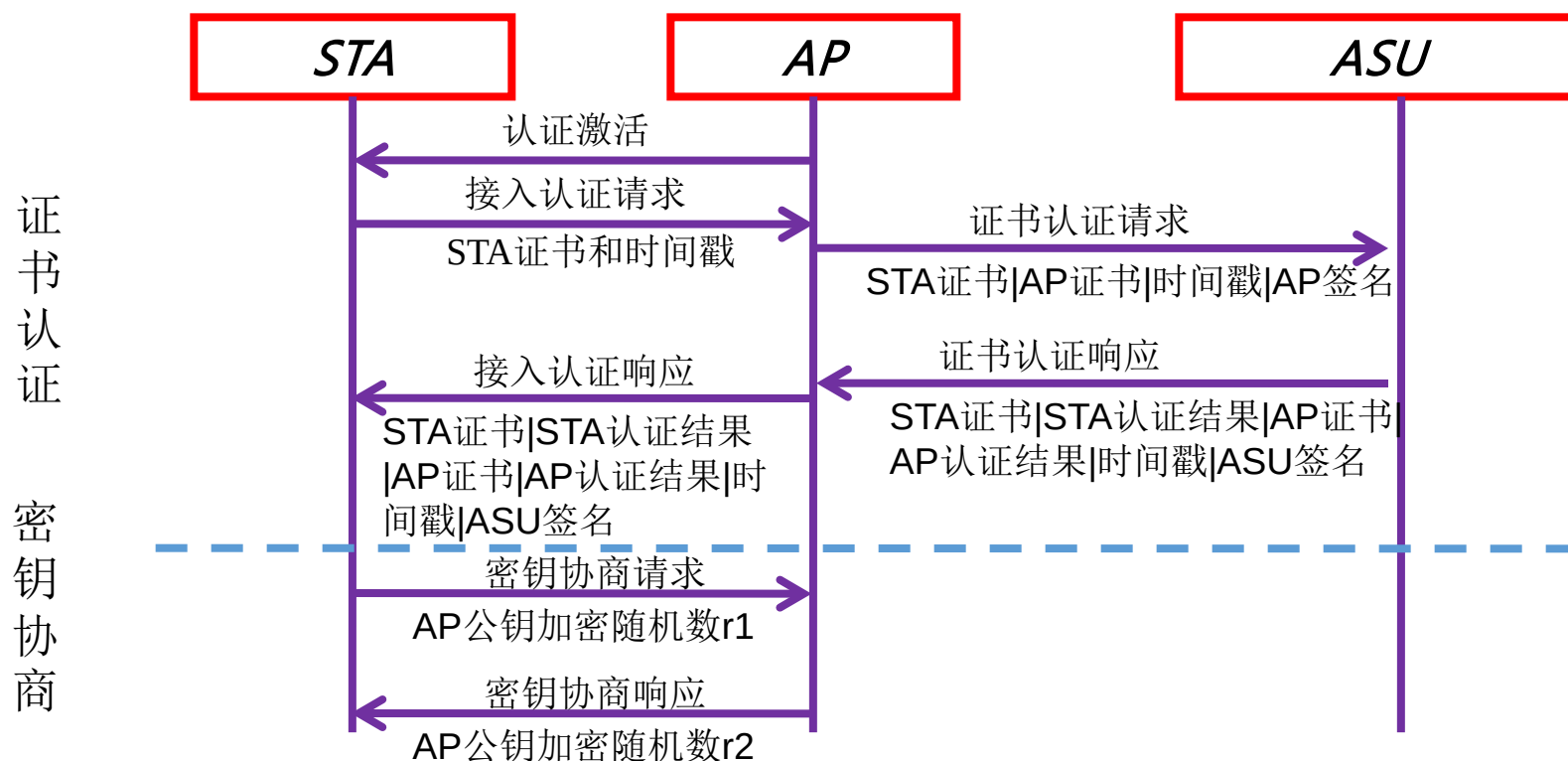
- 基于证书的认证阶段：完成接入设备和接入点之间的双向身份认证，并生成两者之间的主密钥（BaseKey, BK)
- 单播密钥协商阶段：利用BK在STA和AP之间协商会话密钥
- 可选的群组密钥通告阶段：通告用于群组通信的群组密钥

无线局域网络安全协议

➤ WAPI协议

✓ 新安全方案

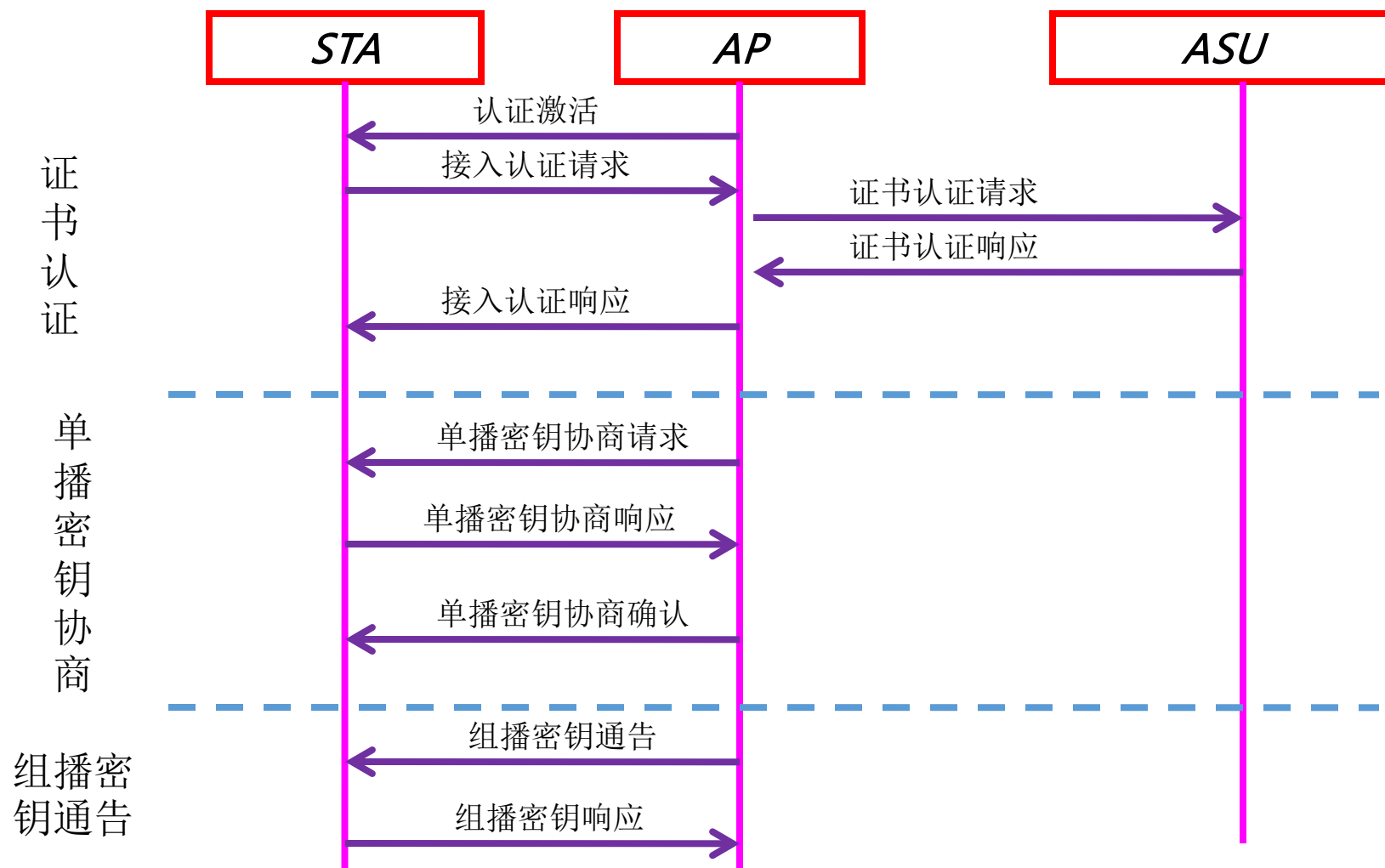
● WAPI修改前的认证与密钥协商过程



无线局域网络安全协议

➤ WAPI协议

✓ 新安全方案：WAPI-XG1认证与密钥协商过程



无线局域网络安全协议

➤ WAPI协议

✓ 新安全方案

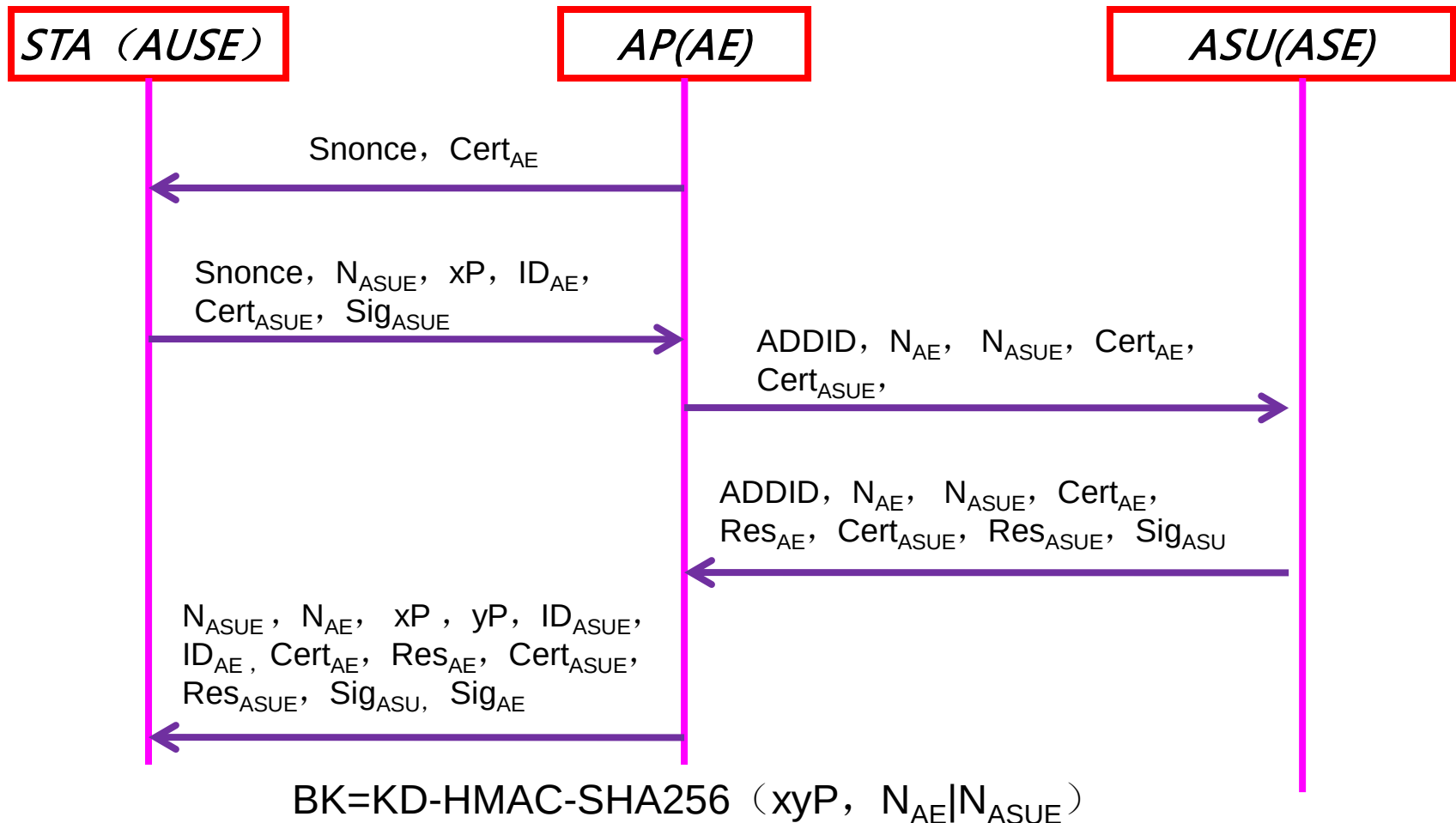
● WAPI-XG1认证与密钥协商过程

- 3个子过程都成功完成后，双方打开受控端口：通信数据利用协商的单播或通告的组播密钥进行安全传输
- WAPI-XG1还支持STA和AP之间基于预共享密钥（PSK）的认证方式
- PSK直接作为主密钥（BK）进行单播密钥协商

无线局域网络安全协议

➤ WAPI协议

✓ WAPI-XG1认证协议



无线局域网络安全协议

➤ WAPI协议

✓ WAPI-XG1认证协议

- 1、认证激活分组：
 - AE向AUSE发送挑战SNonce和自己的证书CertAE来激活双向证书认证
- 2、接入认证请求分组：
 - ASUE产生椭圆曲线DH(ECDH)密钥交换的临时私钥 x ，临时公钥 xP 以及随机数 N_{ASUE} ，连同证书CertASUE、SNonce以及签名SigASUE作为接入认证分组
 - SigASUE：对SNonce、 N_{ASUE} 、 xP 和CertASUE签名

无线局域网络安全协议

➤ WAPI协议

✓ WAPI-XG1认证协议

● 3、证书认证请求分组：

- 检查SNonce和SigASUE的有效性。通过检查后，AE生成随机数NAE，并构造证书认证分组
- ADDID：STA和AP的MAC地址

● 4、证书认证响应分组：

- 验证AE和ASUE的证书，根据验证结果ResAE，ResASUE构造证书认证响应分组，并附加签名SigASU，发送给AE

无线局域网络安全协议

➤ WAPI协议

✓ WAPI-XG1认证协议

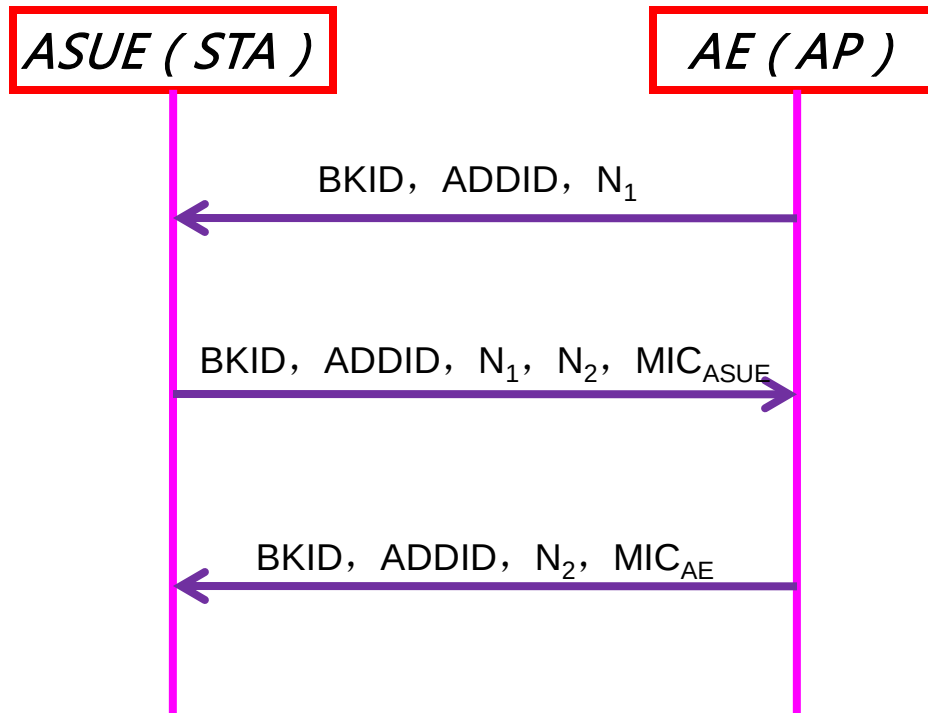
● 5、接入认证响应分组：

- AE收到认证分组后，检查NAE和签名SigASU的有效性。验证通过后生成临时私钥 y 和临时公钥 yP ，使用 y 和ASUE的临时公钥 xP 进行ECDH计算，得种子密钥 xyP ，利用密钥导出算法KD-HMAC-SHA256生成基密钥
- ASUE收到认证分组后，检查NASUE和签名SigASUE和SigASU及证书验证结果Res的有效性。验证通过后，使用 x 和AE的临时公钥 yP 计算种子密钥 xyP ，用密钥导出算法KD-HMAC-SHA256生成基密钥

无线局域网络安全协议

➤ WAPI协议

✓ WAPI-XG1的单播密钥协商协议



$BMK = KD\text{-}HMAC\text{-}SHA256 (BK, ADDID|N_1|N_2)$

无线局域网络安全协议

➤WAPI协议

✓WAPI-XG1的单播密钥协商协议

●1、单播密钥协商请求分组：

■AE向ASUE发送单播密钥协商请求分组。包括：基密钥标识BKID，ASUE和AE的MAC地址ADDID，AE询问N1

●2、单播密钥协商响应分组：

■ASUE利用随机数生成器产生ASUE询问N2，然后利用基密钥BK、AE询问N1和ASUE询问N2，密钥导出算法KD-HMAC-SHA256，生成单播密钥UMK，并扩展成单播会话密钥USK（包括单播数据的加密密钥（UEK）、单播数据的认证密钥（UCK）、组播密钥的加密密钥（KEK）以及协议消息认证密钥（MAK））。利用MAK计算消息认证码
 $MIC_{ASUE} = \text{HMAC-SHA256}(\text{MAK}, \text{BKID} \parallel \text{ADDID} \parallel \text{N1} \parallel \text{N2})$ ，并构造单播密钥协商分组给AE

无线局域网络安全协议

➤WAPI协议

✓WAPI-XG1的单播密钥协商协议

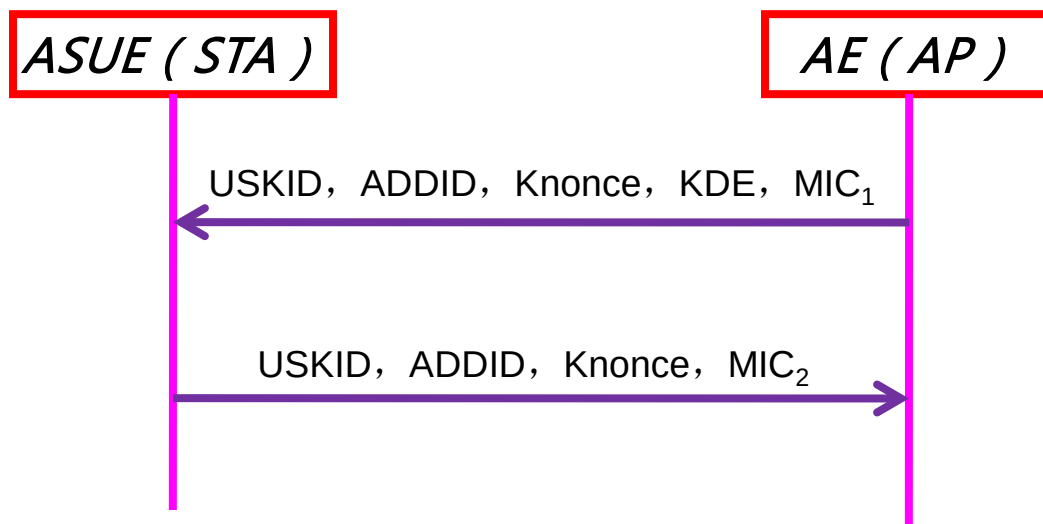
●3、单播密钥协商确认分组：

- AE收到响应分组后，检查询问N1是否正确，如果正确则按同样的方式生成单播会话密钥，并且验证单播密钥协商响应分组中的消息认证码MICASUE，验证通过则计算 $MICAE = HMAC\text{-}SHA256(MAK, BKID|ADDID|N2)$ ，并构造单播密钥协商确认分组发送给ASUE
- ASUE收到确认分组后，验证N2和消息认证码MICAE的有效性，通过则进行下一步

无线局域网络安全协议

➤ WAPI协议

✓ WAPI-XG1的组播密钥通告协议



无线局域网络安全协议

➤ WAPI协议

✓ WAPI-XG1的组播密钥通告协议

● 1、组播密钥通告分组：

■ AP将随机数生成算法产生的组播主密钥利用KEK加密，向STA通告组播密钥。其中USKID为单播会话密钥标识，Knonce为密钥通告标识，KDE为用KEK加密的组播密钥， $MIC1 = HMAC-SHA256(MAK, USKID | ADDID | KDE | Knonce)$

● 2、组播密钥响应分组：

■ 验证MIC1的有效性。通过后，解密KDE得到组播主密钥，并扩展生成组播加密密钥和完整性校验密钥，然后计算 $MIC2 = HMAC-SHA256(MAK, USKID | ADDID | Knonce)$ ，生成组播密钥响应分组给AE，同时受控端口的状态设置为“On”

● AE验证MIC2和Knonce的有效性。通过后，将受控端口的状态设置为“On”

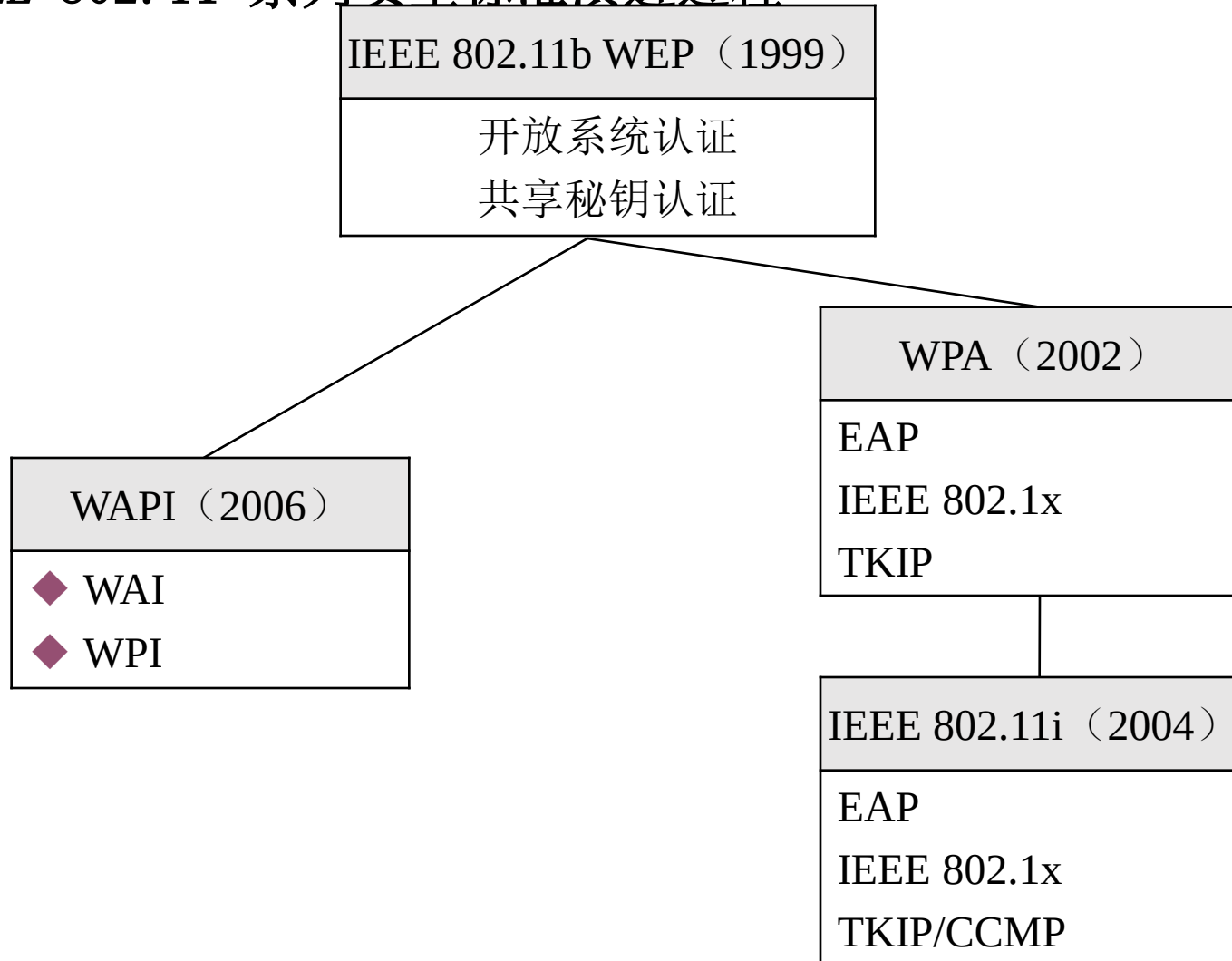
无线局域网络安全协议

➤ WLAN安全技术的演进

- ✓ 为了应对WLAN技术发展所带来的安全威胁，保证STA与AP之间的安全通信，各个组织制定了相应的WLAN安全标准。但从发展过程来看，这些标准初期往往存在一些设计缺陷或不足，不能完全保证WLAN的安全，一度成为阻碍无线局域网发展的最重要的因素，但其始终在向更高的安全目标演进。IEEE 802.11系列安全标准的演进过程如图所示。

无线局域网络安全协议

➤ IEEE 802.11 系列安全标准演进过程



IEEE 802.11 系列安全标准演进过程

无线局域网络安全协议

➤无线网络安全标准比较

✓WEP

- WEP加密机制，WEP基于RC4算法，易于实现，却又被发现存在安全漏洞。例如弱密钥、IV重用等问题。
- 采取静态共享密钥，IEEE 802.11b没有明确密钥管理机制，很多网络出现全网共享一个密钥的情况。
- 采用开放系统认证和共享密钥认证，其中开放式系统认证不能提供真正意义上的认证功能，而共享式密钥认证是单向认证机制，易受到中间人攻击。
- 消息的完整性保护机制采用了CRC32方法，但CRC32方法并不能抵制数据篡改行为。

无线局域网络安全协议

➤ 无线网络安全标准比较

✓ WPA

- 前向兼容，提供WEP的改进算法TKIP。TKIP仍然采用RC4算法，但增加了IV及密钥的长度，使用新IV序列规则防范重放攻击、新密钥构建机制防范弱密钥问题。
- 采用密钥更新机制，弥补WEP安全漏洞。
- 采用IEEE 802.1x/EAP认证机制，支持双向认证。
- 采用Michael算法实现数据完整性保护。

无线局域网络安全协议

➤ 无线网络安全标准比较

✓ WAPI

- 采用公开密码体制椭圆曲线密码算法和秘密密钥体制的分组密码算法。
- 使用数字证书，降低认证复杂度，提高了通信效率。
- 集中管理或者分布式集中管理密钥，便于系统扩展。
- 使用消息散列算法实现消息完整性校验。
- 独立设计，不依赖于IEEE 802.11标准，不用过多考虑前向兼容问题。

无线局域网络安全协议

➤ 无线网络安全标准比较

✓ IEEE 802.11i

- 提供TKIP以及基于AES的CCMP加密机制，AES本身是相当灵活的算法，支持任意长度的数据包，其安全性能远远高于RC4。CCMP基于AES的CCM模式，结合Counter模式完成数据包的加解密处理，结合CBC-MAC模式完成认证处理。
- 引进了RSN体系，强制规定必须实现CCMP。
- 支持IEEE 802.1x/EAP体系、EAP-TLS、RADIUS及共享密钥。
- 具有密钥管理算法，采用密钥分层衍生管理机制。

无线局域网络安全协议

➤ 无线网络安全标准比较

安全功能		WEP	WPA	IEEE 802.11i	WAPI
认证和加密	认证	单向认证	双向认证 IEEE 802.1x架构 EAP协议	双向认证 IEEE 802.1x架构 EAP协议	双向认证 WAI协议 (公钥证书)
	加密	加密密钥短, 易被破解	TKIP算法, 安全性较高	TKIP/CCMP算法, 安全性较高	WPI协议 (SMS4算法)
	绑定关系	认证和加密使用同一密钥, 绑定使用	认证与加密协议分离; 认证与加密算法可未绑定使用	认证与加密协议分离; 认证与加密算法可未绑定使用	认证与加密协议分离; 认证与加密算法绑定使用
	终端实现	绑定	现有终端均绑定使用, 未提供“认证+不加密”模式; 可升级支持	现有终端均绑定使用, 未提供“认证+不加密”模式; 可升级支持	现有终端支持算法实现未开启使用
完整性		未定义	支持	支持	支持
安全性		安全性较低	安全性较高	安全性较高	安全性较高